TEVORA™

# VMware Telco Cloud Platform

## Product Applicability Guide for NIST 800-53 R5

February 27, 2026

# Table of Contents


Table of Contents ..... 2
Background ..... 5
VMware Telco Cloud Platform and NIST 800-53 R5 ..... 5
What is the VMware Telco Cloud Platform? ..... 6
What is NIST? ..... 6
Revision History ..... 7
Design Subject Matter Experts ..... 7
Trademarks and Other Intellectual Property Notices ..... 7
Disclaimer (Tevora) ..... 8
Disclaimer (Broadcom) ..... 8
Executive Summary ..... 9
Introduction ..... 9
What is NIST 800-53? ..... 9
How does NIST 800-53 work? ..... 9
Scope and Approach ..... 11
Our Approach ..... 11
In-Scope VMware Product List ..... 13
Overview of Broadcom and NIST 800-53 Requirement Mapping ..... 15
VMware Control Capabilities ..... 16
VMware Validated Design and Software Development Process ..... 16
Core and Administrative Control Categories ..... 17
Broadcom Administrative Support for NIST Control Families ..... 17
Broadcom Core Support for NIST Control Families ..... 18
VMware Core Controls ..... 19
Access Control (AC) ..... 20
NIST Controls AC1–AC25 ..... 20
Applicable Security Lens: ..... 20
Applicable VMware Product(s): ..... 20
VMware Product Capabilities ..... 20
Audit and Accountability (AU) ..... 22
NIST Controls AU1–AU16 ..... 22
Applicable Security Lens: ..... 22
Applicable VMware Product(s) ..... 22
VMware Product Capabilities ..... 22
Assessment, Authorization, and Monitoring (CA) ..... 23
NIST Controls CA1–CA9 ..... 23
Applicable Security Lens: ..... 23
Applicable VMware Product(s): ..... 23
VMware Product Capabilities ..... 23
Configuration Management (CM) ..... 24

NIST Controls CM1–CM12 ..... 24
Applicable Security Lens: ..... 24
Applicable VMware Product(s): ..... 24
VMware Product Capabilities ..... 24
Identification and Authentication (IA) ..... 26
NIST Controls IA1–IA12 ..... 26
Applicable Security Lens: ..... 26
Applicable VMware Product(s) ..... 26
VMware Product Capabilities ..... 26
System and Services Acquisition (SA) ..... 28
NIST Controls SA1–SA19 ..... 28
Applicable Security Lens: ..... 28
Applicable VMware Product(s): ..... 28
VMware Product Capabilities ..... 28
System and Communications Protection (SC) ..... 30
NIST Controls SC1–SC41 ..... 30
Applicable Security Lens ..... 30
Applicable VMware Product(s): ..... 30
VMware Product Capabilities ..... 30
System and Information Integrity (SI) ..... 32
NIST Controls SI1–SI1 ..... 32
Applicable Security Lens ..... 32
Applicable VMware Product(s): ..... 32
VMware Product Capabilities ..... 32
VMware Administrative Control ..... 34
Awareness and Training (AT) ..... 35
NIST Controls AT1–AT5 ..... 35
Applicable VMware Product(s): ..... 35
Individual Participation (IP) ..... 36
NIST Controls IP1–IP6 ..... 36
Applicable Security Lens: ..... 36
Contingency Planning (CP) ..... 37
NIST Controls CP1–CP13 ..... 37
Applicable Security Lens: ..... 37
Applicable VMware Product(s): ..... 37
Incident Response (IR) ..... 38
NIST Controls IR1-IR10 ..... 38
Applicable Security Lens: ..... 38
Maintenance (MA) ..... 39
NIST Controls MA1–MA6 ..... 39
Applicable Security Lens: ..... 39
Applicable VMware Product(s): ..... 39

Media Protection (MP) ..... 40
NIST Controls MP1–MP8 ..... 40
Applicable Security Lens: ..... 40
Applicable VMware Product(s): ..... 40
Physical and Environmental Protection (PE) ..... 41
NIST Controls PE1–PE22 ..... 41
Applicable Security Lens: ..... 41
Applicable VMware Product(s): ..... 41
Privacy Authorization (PA) ..... 42
NIST Controls PA1–PA4 ..... 42
Applicable Security Lens: ..... 42
Planning (PL) ..... 43
NIST Controls PL1–PL11 ..... 43
Applicable Security Lens: ..... 43
Personnel Security (PS) ..... 44
NIST Controls PS1–PS8 ..... 44
Applicable Security Lens: ..... 44
Risk Assessment (RA) ..... 45
NIST Controls RA1–RA9 ..... 45
Applicable Security Lens: ..... 45
Applicable VMware Product(s): ..... 45
Conclusion ..... 46
Bibliography ..... 47
Appendix A: NIST 800-53 Control Mapping ..... 48
Appendix B: Telco Cloud Platform Product Capability Relationship with NIST 800-53 ..... 49
vSAN ..... 49
Telco Cloud Platform ..... 49
NSX ..... 51
ESX ..... 56
vCenter ..... 67
Telco Cloud Automation ..... 80
Tanzu Kubernetes Grid ..... 84
About Tevora ..... 91
About Broadcom ..... 91

# Background

In this Product Applicability Guide (PAG), we will provide an evaluation of VMware products that make up and support the VMware Telco Cloud Platform, and how they may support NIST 800-53 Rev. 5 (NIST 800-53) controls. These products virtualize and abstract the physical technology layers such as computers, storage, and network -the essence of Telco Cloud Platform. The evolving technology landscape that is modernizing the data center is also modernizing the virtual desktop environment and mobile device management while making inroads to consolidate and automate Information Technology (IT) resources. Broadcom prioritizes data protection and system security features within the Telco Cloud Platform. Broadcom developed a framework that incorporates Telco Cloud Platform product capabilities aligned to NIST 800-53 controls. Using NIST 800-53 as a foundational risk framework and security control catalog, the framework maps VMware products to control requirements and weave together VMware product capabilities with compliance requirements and cybersecurity controls.

NIST 800-53 provides organizations with a tested baseline of controls. It can be used to establish and refine a comprehensive data protection and cybersecurity program. Ultimately, the risks an organization faces are mitigated by controls, and the PAG provides one perspective on how VMware products can assist organizations with managing their cyber risks and implementing a stronger IT security control program.

Broadcom engaged Tevora, an independent third-party IT audit firm, to conduct a review of the Telco Cloud Platform solution alignment to NIST 800-53. This document is the culmination of Tevora's discussions with Broadcom product teams to perform a thorough evaluation of VMware product capabilities mapped to NIST 800-53 controls.

Tevora is a leading security consulting firm specializing in enterprise risk, compliance, information security solutions, and threat research. Tevora offers a comprehensive portfolio of information security solutions and services to clients in virtually all industries. This PAG will navigate readers through the NIST 800-53 standard and highlight applicable VMWARE product capabilities.

## VMware Telco Cloud Platform and NIST 800-53 R5

Today's infrastructures are heterogeneous in nature, built upon collaborations between internally constructed products and third-party sourced components, all guided by a customer's complex business and compliance requirements.

Broadcom approaches compliance with a view that understands the complexity in environments and addresses those areas where virtualization can be leveraged to develop a more secure environment. This focused view on compliance is reflected in the VMware Compliance Solutions framework, which allows for a wide-ranging adoption of regulatory controls.

The phrase "security by design" identifies architectural decisions and default settings inside VMware products that are integrated into the product lifecycle. This approach reflects the process Broadcom follows to weave in security through all stages of the product lifecycle, and not as an afterthought. A compliance-capable design follows the philosophy that mapping Telco Cloud Platform solution capabilities to NIST 800-53 security requirements can result in a solution that has been vetted as compliance capable. This overlap between products and compliance requirements establishes a new level

marrying security and non-security product capabilities to also achieve operational innovation. Due to the breadth of the NIST compliance framework, Broadcom selected NIST 800-53 as its foundation for all future PAGs and as the acknowledgment across industry standards that have been derived from the larger NIST risk framework.

## What is the VMware Telco Cloud Platform?

VMware Telco Cloud Platform refers to a cloud-based platform specifically designed for telecommunications service providers (CSPs), offering advanced features for managing and automating virtualized network functions (VNFs) and cloud-native network functions (CNFs) with capabilities like unified automation, orchestration, and multi-domain assurance.

## What is NIST?

The National Institute of Standards and Technology (NIST) was founded in 1901 and is now part of the U.S. Department of Commerce. NIST is one of the nation's oldest physical science laboratories. Today, NIST measurements support the smallest of technologies to the largest and most complex of human-made creations—from nanoscale devices so tiny that tens of thousands can fit on the end of a single human hair, up to earthquake-resistant skyscrapers and global communication networks. NIST also assists the federal government in issuing standards to meet the provisions and requirements such as the Federal Information Security Management Act (FISMA).

# Revision History

| Date | Rev | Author | Comments |
|---|---|---|---|
| February 27, 2026 | 1.0 | Tevora | Initial Publication |

# Design Subject Matter Experts

The following people provided key input into this whitepaper.

| Name | Email Address | Role/Comments |
|---|---|---|
| Luke Mueller | lmueller@tevora.com | Co-Author |
| Chris Aiken | caitken@tevora.com | Co-Author |
| Sorin Amihalachioaie | sorin.amihalachioaie@broadcom.com | Peer Reviewer |
| Sergii Stepanenko | sergii.stepanenko@broadcom.com | Peer Reviewer |
| Volkan Ozcelik | volkan.ozcelik@broadcom.com | Peer Reviewer |
| Bob Plankers | bob.plankers@broadcom.com | Peer Reviewer |

# Trademarks and Other Intellectual Property Notices

VMware products and solutions discussed in this document are protected by U.S. and international copyright and intellectual property laws. VMware is a registered trademark or trademark of Broadcom, Inc. and its subsidiaries in the United States and other jurisdictions. All other marks and names mentioned herein may be trademarks of their respective companies.

| Solution Area | Telco Cloud Infrastructure Tier Key Products |
|---|---|
| Orchestration | Telco Cloud Automation |
| Infrastructure as a Service (IaaS) | VMware ESX™, VMware vCenter®,<br>VMware vSAN™, VMware NSX® |
| Containers as a Service (CaaS) | Tanzu Kubernetes Grid |

## Disclaimer (Tevora)

The opinions stated in this guide concerning the applicability of VMware® products to the NIST 800-53 framework are the opinions of Tevora. All readers are advised to perform individual product evaluations based on organizational needs.

## Disclaimer (Broadcom)

This document is intended to provide general guidance for organizations that are considering VMware solutions to help them address compliance requirements. The information contained in this document is for educational and informational purposes only. This document is not intended to provide regulatory advice and is provided “AS IS.” Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of regulatory compliance requirements

# Executive Summary

## Introduction

### What is NIST 800-53 R5?

NIST Special Publication (SP) 800-53 Rev. 5 has been developed by NIST to further its statutory responsibilities under the Federal Information Security Management Act (FISMA), Public Law (P.L.) 107–347. It represents the culmination of a year-long initiative to update the content of the security controls catalog and the guidance for selecting and specifying security controls for federal information systems and organizations. The project was conducted as part of the Joint Task Force Transformation Initiative in cooperation and collaboration with the Department of Defense, the Intelligence Community, the Committee on National Security Systems, and the Department of Homeland Security.

While the initial intent of NIST 800-53 was to provide guidance and criteria for federal information systems, revisions have been made over the past few years for widespread adoption across various commercial and private industries. The updates provided consolidated control catalogs, integrated supply chain risk management, added best practice updates to controls, and improved control relationship descriptions.

The fifth revision formal publication was published in September 2020 and updates preceding publications within the areas of:

- Insider Threats
- Advanced Persistent Threats
- Software Application Security (including web applications)
- Supply Chain Security
- Social Networking, Mobile Devices, and Cloud Computing
- Cross-Domain Solutions
- Industrial/Process Control Systems
- Privacy

### How does NIST 800-53 work?

The NIST 800-53 standard requires organizations to comply with a robust set of criteria. The criteria are broken down into 20 control families (listed below) and provide ratings of impact to the business or organization.

Ratings are either Low-Impact, Moderate-Impact, or High-Impact. These risk ratings identify the specific controls to be implemented within each control family.

- Access Control (AC)
- Awareness and Training (AT)
- Audit and Accountability (AU)
- Assessment, Authorization, and Monitoring (CA)
- Configuration Management (CM)
- Contingency Planning (CP)
- Identification and Authentication (IA)

- Individual Participation (IP)
- Incident Response (IR)
- Maintenance (MA)
- Media Protection (MP)
- Privacy Authorization (PA)
- Physical and Environmental Protection (PE)
- Planning (PL)
- Program Management (PM)
- Personnel Security (PS)
- Risk Assessment (RA)
- System and Services Acquisition (SA)
- System and Communications Protection (SC)
- System and Information Integrity (SI)

To derive the specific risk rating, a "Three-Tiered Risk Management" approach allows organizations a strategic viewpoint, not a solely compliance-based viewpoint, on security program development. The tiers are used to conclude the applicable risk rating that ultimately results in identifying the specific controls within each control family that are applicable. The risk is derived based on the following tiered risk approach:

- Tier 1 – Organization
- Tier 2 – Mission/Business Processes
- Tier 3 – Information Systems

All control families may not be applicable to an organization, depending on their size and scope of business. Each control takes the "Three-Tiered Risk Management" model into account and provides supplemental guidance on what a well-defined control looks like.

These controls will aid Communication Service Providers (CSP) moving forward within a shifting regulatory landscape. While the standard is lengthy, it would be advantageous for any organization to define and/or align their security program against it, especially those organizations evaluating overseas expansion.

## Scope and Approach

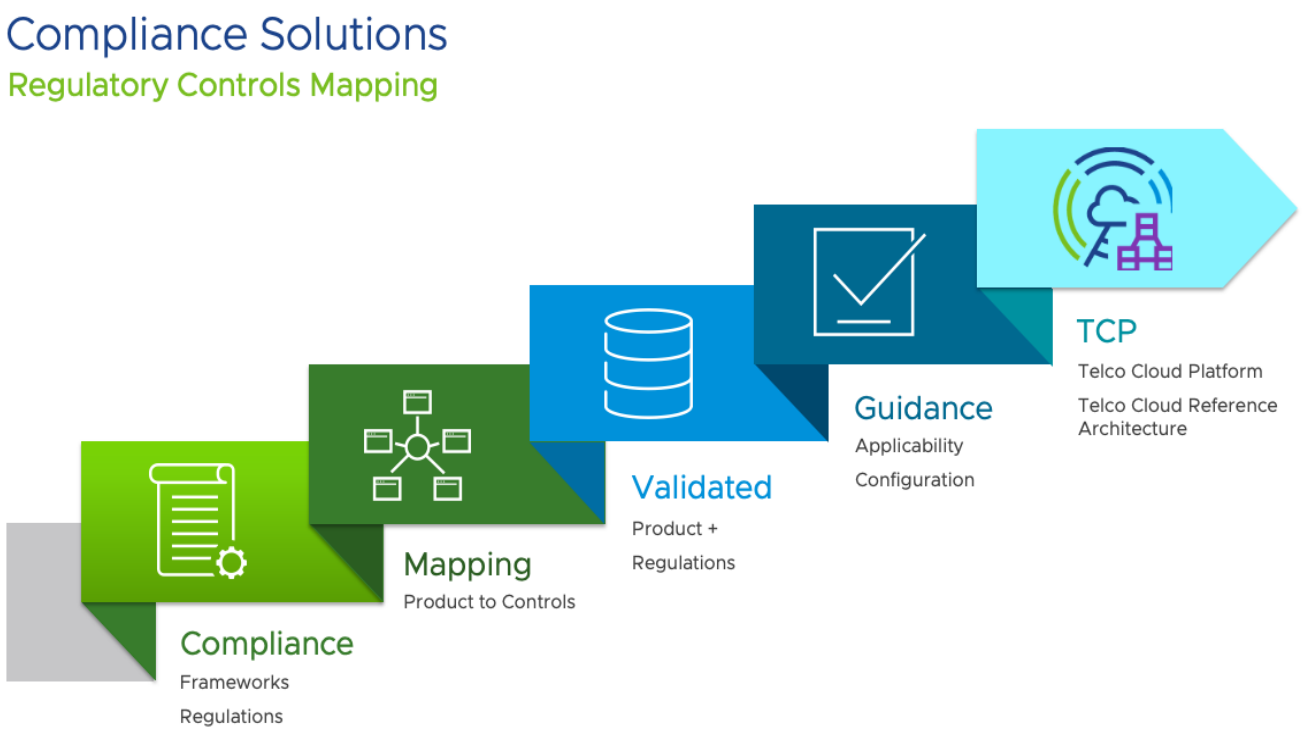
VMware Telco Cloud Platform solution covers a wide number of products and architectures. The platform and each of its component products contain features that could be mapped to some NIST 800-53 controls. Of the 20 total control families, 17 had mapping overlaps to Telco software capabilities. This guide expands to account for Telco Cloud Infrastructure Tier components underneath the Telco Cloud Platform umbrella. Telco Cloud Infrastructure Tier provides the virtualization run-time environment with network functions and resource isolation for VM and container workloads. Virtualized compute, storage, and networking are delivered as an integrated solution through VMware vSphere®, VMware vSAN™, and VMware NSX®. The infrastructure tier is the lowest tier of the Telco Cloud Platform. It is aimed at VM-based Virtual Network Functions (VNFs) and is delivered through a Virtual Infrastructure Manager (VIM) layer. The infrastructure tier is optimized for telco-class workloads to enable the delivery of quality and resilient services. Infrastructure high availability, performance, and scale considerations that are built into this tier form the foundation for upper-level tiers. The scope of this guide is limited to those requirements supported either technically or through direct API integration. Additional technologies required in addition to VMware products are not identified. People and process controls are defined as administrative controls, in support of NIST 800-53 control intents.

## Our Approach

This Product Applicability Guide (PAG) is intended to provide information for all security and compliance practitioners on Tevora's recommended usage of the VMware technical stack to address regulatory compliance obligations and enhance the security of their services through the security and compliance framework of NIST 800-53. It is up to each organization to identify the applicable NIST 800-53 controls and requirements that are in scope. The PAG focuses on capabilities of the Telco Cloud Platform solution at the control family level, as each organization will need to identify its control scope based on risk ratings and to perform its own risk rating and selection of controls based on the organization's scope and the relevance to its objectives. Thus, controls may vary within control families based on risk ratings.

Appendix B outlines specific product capabilities for Telco Cloud Platform and their alignment to NIST 800-53 control families.

In addition to the NIST 800-53 control families, we used eleven (11) security lenses that serve as a baseline to evaluate the Telco Cloud Platform solution. From the ground up, Broadcom strives to design, define, and deliver compliance solutions to customers. The compliance solution begins with a compliance context (e.g., requirements from the appropriate standards in question). Next, the technical requirements applicable to the VMware products are mapped to in-scope compliance requirements. Finally, an independent audit evaluation of the design is conducted. The output is a solution that has interwoven compliance requirements into the end solution available to customers. Below is an overview of this process




Outside of the process described above, these eleven (11) areas are broad categories of controls that are implemented within today's security programs. They can be used to further understand the broader technology concepts used to build security architectures and to implement controls to mitigate risks.

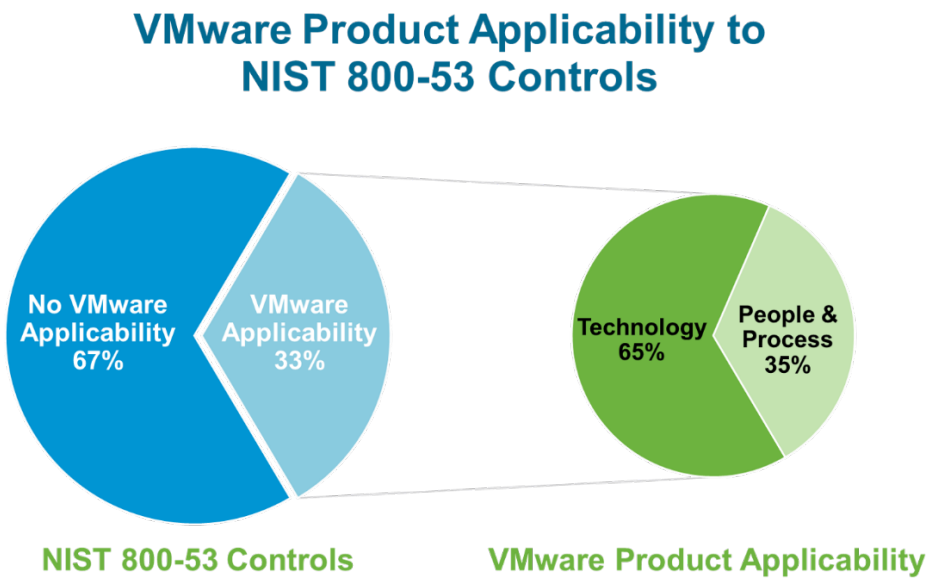
The eleven (11) security lenses include:

- Automated Security
- System Hardening
- Compliance Validation
- System Access
- Data Segmentation
- System Monitoring
- Data Encryption & Protection
- Network Protection
- Endpoint Protection
- Trusted Execution/Secure Boot
- Software Development Lifecycle

Evaluating the Telco Cloud Platform and its components through the additional layer of security lenses helps security and compliance practitioners understand how products deliver the features required not only to support compliance with the NIST 800-53 standard but also to comport with general security best practices.

Tevora reviewed the high-level product design, followed by a detailed examination of data flows, features, architectures, and capabilities across all in-scope products to identify applicable controls. The testing considered all potential configurations that allow Telco Cloud Platform components to support each requirement.

The evaluation produced this guide to provide executives, technology experts, and security and compliance practitioners with insight to enhance security and compliance postures using VMware products. The flexibility of Telco Cloud Platform during deployment allows for connection with preexisting systems to further fortify security, privacy, and compliance. Understanding this flexibility is key to understanding how VMware products can be deployed with continuous compliance in mind.




## In-Scope VMware Product List

VMware Telco Cloud Platform is a purpose-built, carrier-grade cloud services platform that enables Communications Service Providers (CSPs) to modernize their networks and rapidly deploy 4G, 5G, and edge network functions (NFs). It is a unified platform that supports both virtual network functions (VNFs) and cloud-native network functions (CNFs) on a consistent, horizontal infrastructure.

The platform is an integrated solution combining the foundational, high-performance VMware infrastructure layer with a multi-domain orchestration and automation solution that accelerates the design, deployment, and lifecycle management of network functions and services across the network. Embedded within the platform, this component allows CSPs to build, manage, and run containerized workloads (CNFs) using a CNCF-conformant Kubernetes distribution, expedite the innovation cycle to deliver new applications and services, reduce operational complexities, and achieve substantial TCO savings over other approaches, further accelerating CSPs' cloud modernization journey to 5G.

The Telco Cloud Infrastructure Tier is the foundation for the Telco Cloud Platform. For detailed information refer to Telco Cloud Platform infrastructure components.

The infrastructure tier focuses on the following major objectives:

- Provide a platform for creating a horizontal, disaggregated platform, supporting hardware and network functions from any vendor.

- Provide the Software-Defined Telco Cloud Infrastructure
- Provide the Software-Defined Storage
- Provide the Software-Defined Networking

The following lists the components associated with the entire Telco Cloud in-scope for this Product Applicability Guide (PAG)

- VMware ESX™ – ESX is a purpose-built bare-metal hypervisor that installs directly onto a physical server. With direct access to and control of underlying resources, ESX is more efficient than hosted architectures and can effectively partition hardware to increase consolidation ratios and cut costs for our customers.
- VMware vCenter® – vCenter provides centralized management of virtual infrastructure. IT administrators can bolster security and availability, simplify day-to-day tasks, and reduce the complexity of managing virtual infrastructure.
- VMware NSX -- NSX is a network virtualization platform which creates, deletes, and restores software-based virtual networks. With network virtualization, the functional equivalent of a network hypervisor reproduces the complete set of Layer 2 through Layer 7 networking services (for example, switching, routing, access control, firewalling, QoS) in software.
- VMware vSAN™ – vSAN is a core building block for Telco Cloud Platform, delivering enterprise-class, flash-optimized, and secure storage for all of the user's critical workloads.
- Telco Cloud Automation – Telco Cloud Automation automates the deployment and management of network functions and services within the Telco Cloud Platform.
- VMware Tanzu Kubernetes Grid – Tanzu Kubernetes Grid provides a Kubernetes platform to run containerized network functions on the Telco Cloud Platform.

The infrastructure components of Telco Cloud Platform, their interactions with each other, and how they meet CSP requirements are described in the Telco Cloud Reference Architecture Guide.

## Overview of Broadcom and NIST 800-53 Requirement Mapping

| Best Practice Area (Lens) | NIST 800-53 | Capability Description | VMware Product Applicability |
|---|---|---|---|
| Automated Security | CP, RA | Automated Deployment, Automated Remediation | • n/a |
| Data Segmentation | PL, SA, SC, SI | Network & Host Firewall, Information Flow | • NSX |
| System Hardening | CM, MP, PS, SA, SC, SI | Configuration Management, Patch Management, Vulnerability Management | • ESX<br>• Tanzu Kubernetes Grid<br>• Telco Cloud Automation |
| Compliance Validation | CM | Configuration Management | • n/a |
| System Access | AC, AT, AU, IA, IR, PE, PL, PS, SC | Two-Factor Authentication, Identity and Access Management | • vCenter<br>• ESX<br>• Tanzu Kubernetes Grid |
| System Monitoring | AT, AU, CA, CM, CP, IR, MA, PE, PL, PS, RA, SC, SI | Security Information Event Monitoring (SIEM), Database Monitoring | • vCenter<br>• Tanzu Kubernetes Grid |
| Data Encryption & Protection | CA, IA, MA, SA, SC, SI, PA | Data at Rest Encryption, Data in Motion Encryption, System Backup & Restore | • vSAN |
| Network Protection | AT, CA, CP, IR, PE, RA, SC | Intrusion Prevention System, Web Application Firewall | • NSX |
| Endpoint Protection | AC, CM | Endpoint A/V and Malware Prevention, File Integrity Monitoring, Data Leakage Protection, Mobile Device Management | • NSX<br>• ESX |
| Trusted Execution/Secure Boot | SC, SI | Execution Integrity | • NSX<br>• ESX |
| Software Development Lifecycle (SDLC) | PL, SA | Configuration Integrity | • Telco Cloud Platform |

# VMware Control Capabilities

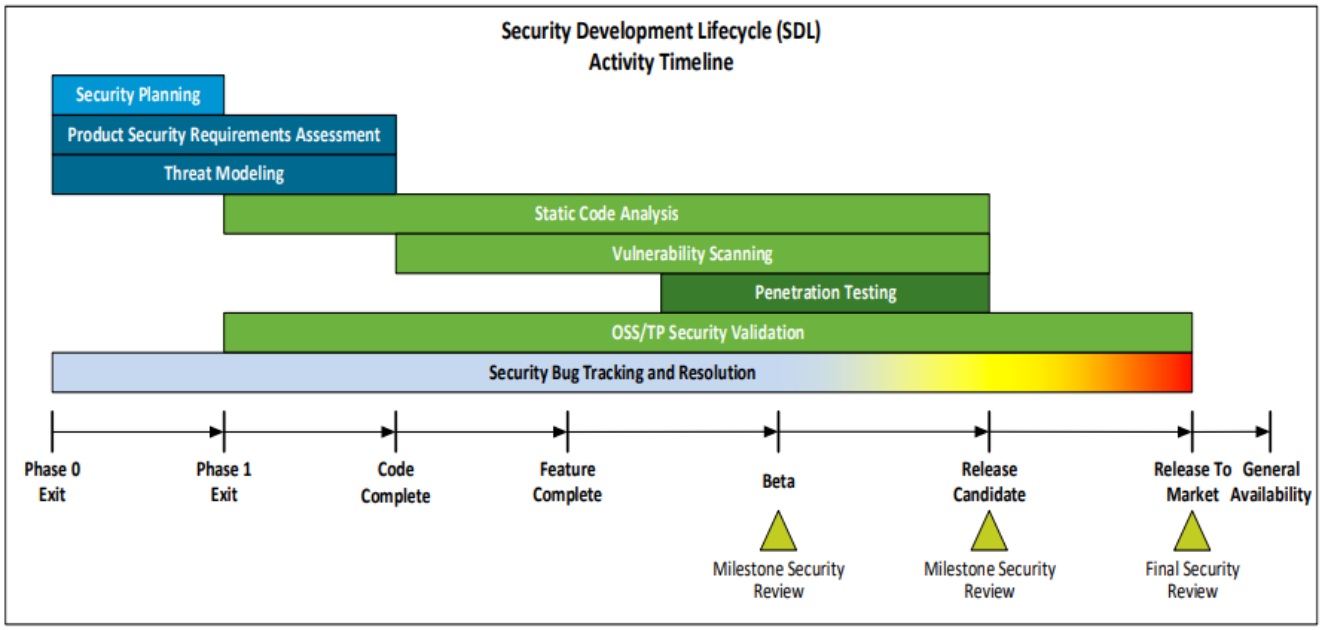
## VMware Validated Design and Software Development Process

Broadcom has developed VMware Telco Cloud Platform™ as a carrier-grade cloud services platform to help Communication Service Providers (CSPs) to expedite the innovation cycle to deliver new NFV applications and services using a reference architecture design that is validated and provides the detail required to confidently deploy the solution. The Telco Cloud Reference Architecture Guide is available to anyone and is published on the Broadcom website.

VMware Security Development Lifecycle (SDL) designs security in all phases of Telco Cloud Platform. This principled approach to designing security, overseen by VMware Product Security from the start, is important to NIST 800-53 compliance, as the products utilized are required to have security interwoven through their underlying substructures, to be supported by administrative policy.

With compliance and security, Broadcom improves the quality of its products and solution platforms that can support organizations using the NIST 800-53 risk-and-control framework.

As further reference to the primary purposes of a control family, each detail segment provides the applicable security lens defined within the Broadcom approach. These lenses are hallmarks of a mature security program addressing common areas of vulnerabilities.



## Core and Administrative Control Categories

The NIST 800-53 authority document historically established "Security Control Class Designation" in the form of Management, Operational, and Technical references. These have been removed from the NIST 800-53 authority document. To streamline the delivery of this PAG and the intent of each control family, those categories were tailored into Core and Administrative. Core control families are those that address the main structure of a NIST program through technical features and capabilities. Administrative control families support multiple control areas through policy development and general program, people, and process management tasks. Further details on these categories and the aligned control families can be found in the following sections.

## Broadcom Administrative Support for NIST Control Families

Many NIST control families establish policies and procedure requirements in the form of documentation, which may cite VMware products or rely on VMwaretechnology capabilities. Other NIST controls may identify people or process requirements that are not specific to VMware products, but these too may rely on underlying VMware product capabilities. While VMware products do not map neatly to these controls, they support their fulfillment through alerts, scripting, and monitoring.

This is a common thread throughout the capabilities discussed below. An organization will be able to deploy VMware products, apply the NIST 800-53 controls, and monitor them through the compliance-capable platform. In this way, implementing policy or operating procedures assists in maintaining a secure and compliant information architecture.

Another key aspect of NIST 800-53 includes supplemental or complementary controls. As a framework, NIST 800-53 provides organizations with an opportunity to enhance controls using additional, complementary controls beyond the baseline of controls associated with each risk rating.

An example of an administrative control family is Incident Response Planning (IR). This control family may require a documented incident response plan or a detailed runbook on audit procedures. Using VMware products such as NSX to strengthen and accelerate discoveries and corrective actions during incident responses is possible because these products provide monitoring, troubleshooting, and remediation capabilities. However, this control family is more focused on the people and process. Thus, this guide will treat the control family as an administrative support control family instead of a core control family because VMware product capabilities support the administration of the control family rather than a core technology control.

The following Control Families fall within Administrative:

- Awareness and Training (AT)
- Contingency Planning (CP)
- Media Protection (MP)
- Physical and Environmental Protection (PE)
- Planning (PL)
- Personnel Security (PS)
- Incident Response (IR)

- Maintenance (MA)
- Risk Assessment (RA)

## Broadcom Core Support for NIST Control Families

For those NIST control families where technology will partially or fully satisfy a control requirement, VMware product capabilities are identified as core to the NIST control family. These are the areas within NIST 800-53 that best highlight how each product provides capabilities to strengthen the security and support a compliance-capable platform.

The details below showcase the Telco Cloud Platform components that support or apply to each NIST control family and their respective High-Impact controls. Each area defines the intention of the NIST family, aligning security lenses as described in the "Our Approach" section (above), and the specifics of the product and their native features that meet control standards. Exhibit 2 (above) illustrates this information.

This guide provides organizations with the opportunity to harness the capability of modern virtualization technology to enhance their security program and processes. Organizations can be confident in their decision to elevate the sophistication of techniques needed to meet complex requirements and secure modern technology infrastructure.

The following Control Families fall within Core:

- Access Control (AC)
- Audit and Accountability (AU)
- Assessment, Authorization, and Monitoring (CA)
- Configuration Management (CM)
- Identification and Authentication (IA)
- System and Services Acquisition (SA)
- System and Communications Protection (SC)
- System and Information Integrity (SI)

# VMware Core Controls

# Access Control (AC)

## NIST Controls AC1–AC25

The Access Control family focuses on the ability of any user, at all permission levels, to reach key elements of the environment. It looks at coverage across subjects such as remote access, the protection of access and authentication, as well as the integrity of the entire authentication process.

## Applicable Security Lens:

- System Access
- Endpoint Protection

## Applicable VMware Product(s):

- ESX
- NSX
- vCenter
- Telco Cloud Automation
- Tanzu Kubernetes Grid

## VMware Product Capabilities

For all products within the Telco Cloud Platform, Access Control can be implemented at a granular level. This is presented through Role-Based Access Control (RBAC) mechanisms natively available. User management interfaces are provided to control password complexity and user profiles and to access review tasks.

As an elevated protection, Broadcom has built third-party integration capabilities to allow organizations to integrate single-sign-on (SSO) tools to strengthen authentication needs and restrict access. Organizations can also integrate their Active Directory (AD)/Lightweight Directory Access Protocol (LDAP) instance through use of VMware Application Programmable Interfaces (APIs) to refine access at all levels of their virtual stack.

Multiple products such as VMware NSX and Telco Cloud Automation, allow administrators to limit concurrent sessions and define account lockout parameters. NSX Manager acts as an LDAP client and interfaces with LDAP servers. Multiple identity sources can be configured for user authentication. NSX Manager provides the ability to administer user accounts via the Administration page, the provided API, and LDAP integration. To ensure that only trusted IPs, subnets, or IP devices are allowed into the environment, vCenter and NSX provide access restriction to an organization's East–West traffic, or Virtual Machine (VM) to Virtual Machine communications. On the north-south traffic, NSX Malware Prevention uses the IDS/IPS engine to extract or intercept the files that are entering the data center. Tanzu Kubernetes Grid supports the use of network-level restrictions such as API server IP whitelisting and node-level SSH key-based access, allowing the ability to limit access to trusted networks and devices.

NSX allows access control through the implementation of micro-segmentation via security policies. The NSX Identity Firewall feature enhances access control down to the virtual networking level, permitting only approved users with the need to access specific virtual machines. Each of the outlined products has

various logging capabilities which can be configured and reviewed. Additionally, servers can be configured into a log repository to hold logs from NSX components and hosts. The Administration portal also offers the ability to configure account lockouts, configure devices and accounts with access control permissions based on compliance requirements. The system administrator account permissions encompass all existing rights, in addition to those associated with administrator accounts, which are immutable.

Additional product capability details can be found at the VMware Compliance IDs listed in *Appendix B*.

# Audit and Accountability (AU)

## NIST Controls AU1–AU16

The Audit and Accountability NIST control family discusses the implementation, governance, and operation of an audit program. As a function of the program, it calls for organizations to ensure the protection of any logs and additional information associated with audit procedures.

## Applicable Security Lens:

- Systems Monitoring
- System Access

## Applicable VMware Product(s)

- ESX
- NSX
- vCenter
- Telco Cloud Automation
- Tanzu Kubernetes Grid

## VMware Product Capabilities

The Audit and Accountability control family speaks to the need for a security program to conduct ongoing audits to maintain integrity and compliance. Implementing the Telco Cloud Platform through the Telco Cloud Reference Architecture Guide provides a reference architecture to identify security requirements throughout the virtual platform, from Hypervisor through to the User Interface that collects audit log data.

Across all products, rich logging features exist to allow administrators to ascertain who logged in, the origin, at what time (coordinated through NTP), and whether the attempt was a success or failure.

Logs can be pointed to third-party management tools through API integration if desired. ESX can be configured to support a persistent log location for locally stored logs. vCenter can be configured for specific-day retention for logs and events. ESX affords administrators the ability to adjust the richness and frequency of audit logs. Tanzu Kubernetes Grid allows notifications to be configured for sending alerts in the event of a processing failure or storage exceeding capacity. Logs can be configured across all products to be sent to a central log server.

To support non-repudiation, administrators are advised to design strong access control surrounding Administrator passwords. All administrative actions should be logged and reviewed on a consistent basis.

For advancing an organizational audit process, it is recommended that a Security Incident Event Management (SIEM) platform be coordinated with VMware products to ingest logs.

Additional product capability details can be found at the VMware Compliance IDs listed in *Appendix B*.

# Assessment, Authorization, and Monitoring (CA)

## NIST Controls CA1–CA9

This control family establishes criteria and controls to ensure that only authorized connections are enabled throughout an organization's environment.

## Applicable Security Lens:

- System Monitoring
- Data Encryption & Protection
- Network Protection

## Applicable VMware Product(s):

- ESX
- vCenter

## VMware Product Capabilities

At its core, the Security Assessment and Authorization control family aims to certify that all systems support security in depth. The interconnections of systems, appropriate authorizations and the processes that support them are key. The applicable VMware products provide ease of configuration natively to support this intent.

vCenter network firewalls can be configured to deny all traffic by default, restricting outbound traffic and protecting corporate devices from malicious traffic entering the environment. Exceptions can be defined granularly to further ensure security in depth.

Products that compose the Telco Cloud Platform solution can support the implementation of continuous monitoring when properly used. Beyond product applicability, organizations are advised to perform proactive penetration tests to meet the full extent of the control area.

Additional product capability details can be found at VMware Compliance IDs listed in *Appendix B*.

# Configuration Management (CM)

## NIST Controls CM1–CM12

This control family establishes management of information systems and software configurations within the environment and how those configurations and baselines are secured. Attention is given to identifying baseline configurations and how any changes to the configurations are managed with the security program.

## Applicable Security Lens:

- System Hardening
- Compliance Validation
- System Monitoring
- Endpoint Protection

## Applicable VMware Product(s):

- vCenter
- ESX
- NSX
- Telco Cloud Automation
- Tanzu Kubernetes Grid

## VMware Product Capabilities

Telco Cloud Reference Architecture Guide contains specified requirements for each component's configuration. This provides a "gold standard" for deployment across the entire suite of products. This standard is developed with security requirements throughout the SDLC.

To further protect any adjustments to information systems configuration, micro-segmentation can be defined through NSX. Routing specifications can be set and protected by tamperproof logging. Active Directory can be integrated to enforce least privilege functionality, based on requirements across the user base. Devices can be isolated to eliminate rogue device infiltration. All configuration and isolation activities can utilize REST API to deliver at scale and in real time.

NSX allows you to insert third-party partner services as a separate service VM that provides endpoint protection services. Service profiles can be created to configure protection for virtual machine groups defined in NSX. As an administrator, you can create groups based on VM name, tags, or identifiers. NSX Administrators can also configure rules to specify a set of virtual machine groups that are to be protected and choose the protection level based on the service profiles. Within the virtual machine copy/paste and drag/drop functionality can be disabled as well as individual ports and protocols.

Telco Cloud Automation allows you to centrally manage configuration templates, system parameters and software versions across cloud and network functions. Software installations can be managed and restricted to essential software within Tanzu Kubernetes Grid. System settings and package versions can be managed through configuration tools and cryptographically signed package management. Photon operating system configurations and system parameters are protected through file permissions ensuring

only privileged users can modify critical settings. Additional product capability details can be found at VMware Compliance IDs listed in *Appendix B*.

# Identification and Authentication (IA)

## NIST Controls IA1–IA12

This control family establishes how an organization should address and protect authentication. The family delves into re-authentication requirements and cryptographic-enabled security. Overall, the intent of the family is to ensure that appropriate measures are employed for the operations and management of Identification and Authentication within an environment.

## Applicable Security Lens:

- Data Encryption & Protection
- System Access

## Applicable VMware Product(s)

- ESX
- NSX
- vCenter
- vSAN
- Telco Cloud Automation
- Tanzu Kubernetes Grid

## VMware Product Capabilities

Telco Cloud Platform requires the use of AES256 cryptographic protocols. To assist with user authentication, Active Directory can be integrated for central management of credentials. To guarantee that no sessions remain unlocked, time-outs and re-authentication can be set across all Telco Cloud Platform infrastructure tier components. The vSAN Encryption feature in vSAN certifies that all data stored within a customer's Telco Cloud Platform environment is encrypted to industry standards.

By default, all session time-outs require user re-authentication. Typically set to 15 to 20 minutes, session time-out thresholds can be configured within the product and adjusted to meet control intents. Products can again harness Active Directory integration to maintain vigilance over authentications to products.

Natively, organizations can harness micro-segmentation to reduce the risk profile of their environment. For this control family, micro-segmentation is particularly important and can be implemented using NSX. Virtual machines (VMs) can be configured to only speak to other VMs in specified situations, based upon security policies.

Across all products, default passwords can be reset. All products in accordance with the Telco Cloud Reference Architecture Guide and SDLC are required to have minimum password standards. Telco Cloud Platform hashes passwords to provide an extra layer of security. Password requirements can include complexity, reuse restrictions, and required password rotation. Telco Cloud Platform components across the suite allow for seamless 2FA deployment through third-party integrations. Administrators viewing all passwords through the Graphic User Interface (GUI) will have passwords for all credentials obscured or masked with asterisks.

System level accounts do not have a default password set during the deployment of the Telco Cloud Automation Manager or Control Plane. Setting these passwords during the deployment ensures that the minimum password requirements are met for the organization.

To note, some authentication controls only have partial matches but are supported across all product components within the Telco Cloud Platform solution. These controls relate to authentication against a certificate authority (CA). The organization has the ability to create default certificates through the platform or import their own from a trusted CA. vSphere performs trust chain validation and expiration checks on these certificates, however, vSphere does not enforce certificate revocation for ESX hosts or vCenter systems.

Additional product capability details can be found at the VMware Compliance IDs listed in *Appendix B*

# System and Services Acquisition (SA)

## NIST Controls SA1–SA19

System and Services Acquisition spans the underlying makeup of an organization's SDLC and the application of security. It focuses on understanding resource allocation; the security engineering principles employed; supply chain protection; and how developers, engineers, and other product development personnel are prepared to perform the duties defined by the organization.

## Applicable Security Lens:

- Data Segmentation
- Data Encryption & Protection
- System Hardening
- Software Development Lifecycle (SDLC)

## Applicable VMware Product(s):

- ESX
- NSX
- vCenter
- vSAN
- Telco Cloud Automation
- Tanzu Kubernetes Grid

## VMware Product Capabilities

The Broadcom approach to security extends into its development process. While constant iteration is a priority, security is interwoven into every stage from ideation and design to development and into production. Static code analysis, security, and privacy considerations at the design phase run through multiple levels of approval, in addition to performance-level assessments. Developers participate in extensive secure code training and regularly attend working sessions in collaboration with security compliance and privacy teams to stay abreast of evolving trends and vulnerabilities.

The overlap in security emphasis between Broadcom internal SDLC processes and the System and Services Acquisition (SA) NIST control family fulfills requirements including process isolation at both personnel level and code level, encryption protocols in transmission, and permission granularity.

Particularly important for this control family is that the ability to meet security requirements can be met during the acquisition process. For organizations looking to secure all levels of their infrastructure, the SDLC extends out into the supply chain and products that are acquired by Broadcom to deliver virtual solutions to the marketplace. For the Telco Cloud Platform solution components, all elements of your virtualized environment are encrypted and secure throughout internetwork transit. Some TCP components such as OpenSSH on the ESX host and the Photon OS can be launched in a FIPS mode to only use FIPS 140-2 validated ciphers.

Broadcom develops whitepapers and other documentation to show the mapping between VMware product capabilities and compliance requirements.

Broadcom designed a framework to continuously provide feedback to product engineering to further solidify product capabilities in support of compliance controls and cyber risk requirements. VMware product mappings and design architecture in support of a compliance-capable platform augment the value of acquiring VMware products.

Additional product capability details can be found at the VMware Compliance IDs listed in *Appendix B*

# System and Communications Protection (SC)

## NIST Controls SC1–SC41

The System and Communications control family addresses the need for protecting information throughout its lifecycle within the environment. It assesses how traffic travels from outside to inside an organization's network and the layers in between.

## Applicable Security Lens

- Data Segmentation
- System Hardening
- System Access
- System Monitoring
- Network Protection
- Data Encryption & Protection
- Trusted Execution/Secure Boot

## Applicable VMware Product(s):

- ESX
- NSX
- vCenter
- vSAN
- Telco Cloud Automation
- Tanzu Kubernetes Grid

## VMware Product Capabilities

One main objective within this control set is minimizing the development of covert channels. Broadcom conducts peer reviews during each development cycle to plug all potential back doors. Telco Cloud Reference Architecture Guide forces security requirements to maintain adequate levels of encryption, and logging. All infrastructure tier components of the Telco Cloud Platform solution include digital signatures and cryptographically strong hash functions.

Micro-segmentation allows logical domain segmentation at a granular isolation level. For DDoS attacks, NSX builds in capabilities to perform malware analysis. These attributes supplement vulnerability scanning capabilities that exist within the SDLC. Network I/O Control can be enabled on vCenter to manage excess capacity, bandwidth or other redundancies to limit the effects of information flooding types of denial-of-service attacks. NSX and other Telco Cloud Platform components grant administrator functionality to restrict remote access to defined protocols, i.e., SSH and RDP.

Beyond protocol restriction, Telco Cloud Platform contains multiple default roles that segment information based on roles at scale. This enables fine grain authentication to be designed and implemented granularly across a designed environment without third-party integration.

vCenter has the capability to restrict cryptographic operations such as key management server (KMS) functions and encrypting/decrypting virtual machine disks to a specific cryptographic role. This prevents

all administrators from having access to cryptographic operations, adding additional granularity into access rights.

The Photon operating system provides a minimal Linux distribution that supports FIPS validated cryptographic modules. The operating system supports kernel hardening, process isolation and SSH key authentication to prevent unauthorized access to system resources.

NSX supports multi-tenancy enabling isolation of security and networking configurations across tenants. NSX users across tenants can access the same NSX Manager to provision networking and security objects on shared hosts. On the ESX host, IP-based storage traffic and vMotion traffic can be isolated from other traffic to further protect them from attack.

All port groups on standard switches can be configured to reject forged transmits, guest MAC address changes and guest promiscuous mode requests. NSX Manager enforces approved authorizations for controlling the flow of management information within the network device based on information flow control policies.

NSX and its micro-segmentation can then enforce defined information flow guidelines. NSX Manager™ can sync with RBAC to restrict access based on specified group names. The information contained within these data flows are then secured at rest with the vSAN Encryption feature in vSAN. ESX further segments processes within resource pools.

User functionality and system management functionality can be segmented from each other within Tanzu Kubernetes Grid by logically partitioning a single Kubernetes cluster into multiple sub-clusters.

VMware security programs and practices establish requirements “by design” to evolve methodologies of protection against new “in-the-wild threats.” This takes effect throughout the development process and is developed into products. Products are tested by first-class vulnerability scans and penetration tests prior to any full release or version update.

Additional product capability details can be found at VMware Compliance IDs listed in *Appendix B*.

# System and Information Integrity (SI)

## NIST Controls SI1–SI1

Maintaining integrity within the system and information it provides is paramount. This control family requires that organizations implement protections concentrated on three key areas: System Monitoring; Software, Firmware, and Information Integrity; and Flaw Remediation.

## Applicable Security Lens

- Data Segmentation
- System Monitoring
- System Hardening
- Data Encryption
- Trusted Execution/Secure Boot

## Applicable VMware Product(s):

- ESX
- NSX
- vCenter
- Telco Cloud Automation
- Tanzu Kubernetes Grid

## VMware Product Capabilities

Through the lens of the "secure by default" directive and the guidance of the security criteria held within the SDLC, VMware Telco Cloud Platform components consistently prioritize system integrity and the information it holds.

To highlight, ESX maintains a secure boot protocol utilizing vSphere Installation Bundles (VIBs). Harnessing the Unified Extensible Firmware Interface (UEFI), the hypervisor refrains from loading unless the signature database (containing the whitelisted and blacklisted signatures) validates. vCenter supports alerts to prevent unauthorized execution within the environment.

If signatures are not validated, the hypervisor fails to activate. ESX does not report system intelligence back on the failure to the session's origin. This is crucial as it protects the integrity of an organization's virtual servers from adversaries targeting intelligence to exploit. NSX natively includes a defined guest introspection framework that allows administrators to conduct analysis on the data plane level from North–South traffic flows.

ESX can use Trusted Platform Modules (TPM) 2.0 to enable advanced security features that prevent malware, remove dependencies, and secure hardware lifecycle operations.

The ESX hypervisor maintains logs for each individual VM by default. These logs contain information including but not limited to power events, system failure information, tools status and activity, time sync, virtual hardware changes, vMotion migrations, and machine clones. By default, 10 of these logs are

retained. This is normally sufficient for most environments, but this configuration must be verified and maintained. All products can send logs to a centralized log server or SIEM for analysis to be conducted.

Finally, all VMs can be configured for destruction upon end of life, defined by the administrator.

Additional product capability details can be found at VMware Compliance IDs listed in *Appendix B*.

# VMware Administrative Control

# Awareness and Training (AT)

## NIST Controls AT1–AT5

This control family is managed through administrative action on the client side and is not applicable to VMware products natively.

Applicable Security Lens:

- System Monitoring
- System Access
- Network Protection

## Applicable VMware Product(s):

- vCenter

# Individual Participation (IP)

## NIST Controls IP1–IP6

Individual Participation in accordance with NIST 800-53 Rev 5 will be governed by Administrative policy. Individual participation focuses on the development and assignment of policies and procedures to protect privacy. It looks at coverage around consent to processing personally identifiable information prior to its collection, redress information that has been reported inaccurately, and the inclusion of privacy notices on organizational forms. This control family is managed through Administrative action on the client side and is not applicable to VMware products natively.

## Applicable Security Lens:

- System Monitoring
- System Access
- Network Protection

# Contingency Planning (CP)

## NIST Controls CP1–CP13

Contingency Planning in accordance with NIST 800-53 will be governed by administrative policy. VMware products such as vCenter can support the need for data backups as detailed within the organization's policy when properly used. Backups of vCenter can be made at a data and configuration level versus traditional storage/image-based backups. This reduces recovery time by letting the system administrator (SA) spin up a new vCenter while simultaneously importing the backed-up data

Further, for components of the control family relating to Predictable Failure and System Recovery & Reconstitution, NSX has been designed to support high availability. VMware Avi Load Balancer can be configured, at the organization's discretion, to automatically distribute workloads across multiple servers to prevent any one server from becoming overloaded. This is to ensure uptime as required by SLAs or other operating needs.

## Applicable Security Lens:

- System Monitoring
- Network Protection
- Automated Security

## Applicable VMware Product(s):

- vCenter
- NSX

# Incident Response (IR)

## NIST Controls IR1-IR10

The Incident Response control family is driven by the creation of organizational policies that address how evolving disasters or security events will be addressed. Telco Cloud Platform infrastructure tier components can assist in the research, auditing, and curtailing of those events attributed to technical elements through integration into IDS/IPS appliances or a SIEM.

In other respects, the breadth of the family is focused on developed administrative policy.

## Applicable Security Lens:

- System Access
- System Monitoring
- Network Protection

# Maintenance (MA)

## NIST Controls MA1–MA6

Most controls listed underneath this control family are performed in accordance with organizational policy. Broadcom monitors all security alerts that can affect VMware products' security and issues a security patch if needed. When configured appropriately, products such as vCenter assist in the updates and patching for complementary VMware products, e.g., ESX.

Moreover, all products are pre-inspected prior to ingestion/deployment and are hashed to elevate security protocols at the deepest levels of the virtual stack.

Lastly, proof of maintenance within NIST is required to ensure that all procedures are being followed as stated in governing policies. All products can generate logs that highlight when maintenance occurred on the component.

## Applicable Security Lens:

- System Monitoring
- Data Encryption & Protection

## Applicable VMware Product(s):

- ESX
- vCenter
- NSX
- Tanzu Kubernetes Grid

# Media Protection (MP)

## NIST Controls MP1–MP8

VMware products can support the controls of this family through organizationally developed policy when properly used. Products within the Telco Cloud Platform do not natively provide features that directly apply to the family's intent. It is recommended to eliminate unnecessary virtual hardware from VMs to reduce potential attack surfaces.

## Applicable Security Lens:

- System Hardening

## Applicable VMware Product(s):

- vCenter
- NSX

# Physical and Environmental Protection (PE)

## NIST Controls PE1–PE22

VMware products can support the controls of this family through organizationally developed policy when properly used. All Telco Cloud Platform components provide backup and recovery capabilities, which will aid the employment of the policy for requirements such as data protection, recovery time objectives (RTO), and recovery point objectives (RPO).

## Applicable Security Lens:

- System Access
- System Monitoring
- Network Protection

## Applicable VMware Product(s):

- NSX

# Privacy Authorization (PA)

## NIST Controls PA1–PA4

Privacy authorization determines the legal authority that permits the collection, use, maintenance, and sharing of personally identifiable information. This control is managed through Administrative action on the client side and is not applicable to VMware products natively.

## Applicable Security Lens:

- System Monitoring
- System Access
- Network Protection

# Planning (PL)

## NIST Controls PL1–PL11

VMware products can support the controls of this family through organizationally developed policy when properly used. Across all products, Broadcom employs secure information-sharing processes. These processes are critical elements of the Telco Cloud Platform reference architecture and include the need for strict design testing requirements.

Each product must clear requirements thresholds prior to deploying for public use. Telco Cloud Platform enables architecture design capabilities allowing the separation of the Management and Workload domains to segregate duties throughout the Telco Cloud Platform solution.

## Applicable Security Lens:

- Data Segmentation
- System Access
- System Monitoring
- Software Development Lifecycle (SDLC)

# Personnel Security (PS)

## NIST Controls PS1–PS8

VMware products can support the controls of this family through organizationally developed policy when properly used. Products within the Telco Cloud Platform solution natively provide features that support the family's intent. These features include general user review reports and log intelligence capabilities.

## Applicable Security Lens:

- System Access
- System Hardening
- System Monitoring

# Risk Assessment (RA)

## NIST Controls RA1–RA9

VMware products can support the controls of this family through organizationally developed policy when properly used. All Telco Cloud Platform components do provide backup and recovery capabilities, which will thus aid the employment of a policy's requirements such as data protection and being able to meet recovery time objectives (RTO) and recovery point objectives (RPO).

## Applicable Security Lens:

- System Monitoring
- Network Protection
- Automated Security

## Applicable VMware Product(s):

NSX ideation to design and through to the end of the product lifecycle, Broadcom has focused on developing methodologies that set this tone.

Through the eleven (11) security lenses and in accompaniment of the Reference Architecture, the Telco Cloud Platform components provide users with a virtualization stack that adheres to the comprehensive requirements of NIST 800-53.

Communication Service Provider (CSP) can seamlessly piece together a full Telco Cloud Platform solution, or a subset made up of individual components, and be confident in the security and privacy measures employed in the products.

# Conclusion

To meet evolving regulatory needs, security programs now must define applicable controls at early stages.

The considerations that Broadcom brings to bear on continuous compliance for clients comes from its development culture, which constructs requirements that balance functionality and security for all deployable products. These policies provide customers with the confidence to include the Telco Cloud Platform solution suite within their architecture and NIST 800-53 security program.

# Bibliography

1. Force, Joint Task. “Security and Privacy Controls for Information Systems and Organizations.” *CSRC*, NIST, 10 Dec. 2020, csrc.nist.gov/pubs/sp/800/53/r5/upd1/final.

# Appendix A: NIST 800-53 Control Mapping

| VMware Product | NIST 800-53 Control Families Supported |
|---|---|
| VMware Telco Cloud Platform | AC, AU, IA, SA, SC, SI, CP |
| VMware vCenter | AC, AU, CA, CM, IA, SA, SC, SI, AT, CP, MA, MP |
| VMware ESX | AC, AU, CA, CM, IA, SA, SC, SI, MA |
| VMware vSAN | IA, SA, SC |
| VMware NSX | AC, AU, CM, IA, SA, SC, SI, CP, MA, MP, PE, RA |
| Telco Cloud Automation | AC, AU, CM, IA, SA, SC, SI, CP |
| VMware Tanzu Kubernetes Grid | AC, AU, CM, IA, SA, SC, SI, MA |

# Appendix B: Telco Cloud Platform Product Capability Relationship with NIST 800-53

## vSAN

| Product | Capability ID | Product Capability | NIST Control Family |
|---|---|---|---|
| vSAN | vSAN_001 | vSAN capacity should be verified with a virtual infrastructure administrator to ensure capacity is sufficient and planned appropriately for normal operations of the Telco Cloud Platform. | SA - System and Services Acquisition |
| | vSAN_002 | The vSAN Health Check is able to download the HCL to check compliance against the underlying vSAN Cluster hosts. To ensure the vCenter is not directly downloading content from the internet, this functionality must be disabled. If this feature is necessary, an external proxy server must be configured. | SC - System and Communications Protection |

## Telco Cloud Platform

| Product | Capability ID | Product Capability | NIST Control Family |
|---|---|---|---|
| Telco Cloud Platform | TCP_001 | Telco Cloud Platform can be backed up and restored with an image-based solution or a file-based solution. | CP - Contingency Planning |
| | TCP_002 | An authoritative time source can be configured to synchronize system clocks, allowing the correlation of events that occur across multiple systems. | AU - Audit and Accountability<br>SC - System and Communications Protection |

| | | | |
|---|---|---|---|
| | TCP _003 | Security patches and updates can be installed for Telco Cloud Platform | SI - System and Information Integrity |
| | TCP _004 | Telco Cloud Platform should use approved Class 3 and Class 4 SSL certificates for software signing and business-to-business transactions. | VMware Best Practice |
| | TCP _005 | Telco Cloud Platform can be configured to not be exposed directly to the internet. | SC - System and Communications Protection |
| | TCP _006 | Access control policies (e.g., identity-based policies, role-based policies, attribute-based policies) and access enforcement mechanisms (e.g., access control lists, access control matrices, cryptography) can be employed on the application server to support the principle of least privilege for users and service accounts. | AC- Access Control |
| | TCP_0 07 | Telco Cloud Platform supports a FIPS mode that only supports secure cryptographic algorithms. This option is only available for new installations and the settings you apply during bring-up are used for future upgrades. You cannot change the FIPS security mode setting after bring-up. | SA - System and Services Acquisition<br>SC - System and Communications Protection |

## NSX

| Product | Capability ID | Product Capability | NIST Control Family |
|---|---|---|---|
| NSX | NSX_001 | NSX system clocks can be synchronized to NTP to enable accurate and universal time source logging. | AU - Audit and Accountability<br>SC - System and Communications Protection |
| | NSX_002 | Virtual network tunnel traffic can be isolated from other traffic either through a VLAN segment or by physical isolation. | SC - System and Communications Protection |
| | NSX_003 | Only trusted hypervisors should be used on the logical network data plane. | SC - System and Communications Protection |
| | NSX_004 | Access permissions to NSX Manager VA can be restricted to intended administrators. | MP - Media Protection<br>AC- Access Control |
| | NSX_005 | NSX Virtual Appliance can be used to verify that IPv4 DNS is authorized and secured. | SC - System and Communications Protection |
| | NSX_006 | NSX backup directory can be stored on a SFTP server with read or write access limited to a specific backup user. | AU - Audit and Accountability |
| | NSX_007 | NSX Manager clusters can have rules applied to it that separate the nodes onto different physical hosts. | SA - System and Services Acquisition |
| | NSX_008 | NSX Manager can be used to download patches or upgrades for the NSX. After installation the MD5/SHA1 output can be validated with the MD5/SHA1 sum values on the Broadcom website. | SI - System and Information Integrity |
| | NSX_009 | NSX comes with pre-defined roles that can be assigned to enable Role Based Access Control. In | AC- Access Control |

| | | | |
|---|---|---|---|
| | | addition, new roles can be developed based on an inventory of functionality to be used as custom roles. This capability can support both Separation of Duties, as well as the concept of Least Privilege. | CM - Configuration Management |
| | NSX_010 | NSX Distributed Firewall supports anti-spoofing measures to detect and block outbound IP packets that contain illegitimate packet attributes. | VMware Best Practice |
| | NSX_011 | NSX has the capability to redirect logs to a SI - System and Information IntegrityEM or copy logs and send them to another logging tool for analysis. | AU - Audit and Accountability |
| | NSX_012 | NSX Manager can be configured to integrate with VMware Cloud Foundation® Identity Broker. This configuration supports non-repudiation of actions taken by an administrator. | IA - Identification and Authentication |
| | NSX_013 | NSX Manager supports device session timeout at the end of the session or after an organization-defined period of timeout. | AC- Access Control |
| | NSX_014 | NSX Manager supports an organization-defined API account lockout duration after repeated failed login attempts | AC- Access Control |
| | NSX_015 | NSX Manager supports an API account lockout policy to limit the number of failed login attempts before locking out the user. | AC- Access Control |
| | NSX_016 | NSX Manager supports an account lockout policy to limit the number of failed login attempts before locking out the user. | AC- Access Control |
| | NSX_017 | NSX Manager can be configured to capture audit records to establish, correlate and investigate events relating to an incident | AU - Audit and Accountability<br>MA - Maintenance<br>SI - System and Information Integrity |

| | | | |
|---|---|---|---|
| | | | IA - Identification and Authentication<br>AC- Access Control |
| | NSX_018 | NSX Manager can be used to configure the minimum password length policy. The default value is 12 characters. | VMware Best Practice |
| | NSX_019 | Multiple NSX Manager nodes are deployed with VIP or external load balancers to preserve network element state information. This helps facilitate continuous network operations with minimal to no disruption. | CP - Contingency Planning |
| | NSX_020 | Client API rate limits, client API concurrency limits and Global API concurrency limits can be configured in NSX Manager to protect the system from denial-of-service (DoS) attacks. | SC - System and Communications Protection |
| | NSX_021 | It is highly recommended to not install/use any software not supported by Broadcom to minimize the threat to infrastructure. Do not add other software components to the NSX appliances as it is an untested configuration and could potentially interfere with the operation of the security functions they provide. | CM - Configuration Management |
| | NSX_022 | NSX patches or upgrades can be installed as soon as the update bundles are available. | SI - System and Information Integrity |
| | NSX_023 | Storage networks can be isolated from any other network to protect against rouge VM attacks. | SC - System and Communications Protection |
| | NSX_024 | The NSX Manager system clock can be configured so time stamps for audit records are mapped to Coordinated Universal Time (UTC). | AU - Audit and Accountability |

| | | | |
|---|---|---|---|
| | NSX_025 | NSX Manager obtains its public key certificates from approved certificate authorities. NSX Manager uses a certificate for each manager and one for the cluster VIP. In some cases, these are the same, but each node and cluster VIP certificate must be checked individually. | SC - System and Communications Protection |
| | NSX_026 | NSX Manager can be configured to conduct backups on an organizational defined schedule. | CP - Contingency Planning |
| | NSX_027 | NSX Manager can be configured to disable SSH by default which will prevent users from bypassing NSX access control and audit controls. SSH can be temporarily turned on when needed. | CM - Configuration Management<br>SC - System and Communications Protection |
| | NSX_028 | The backup-users password can be configured to meet the organization's defined password requirements. | IA - Identification and Authentication<br>MA - Maintenance |
| | NSX_029 | A valid TLS certificate or a self-signed certificate can be used for communication between NSX Manager and VMware Cloud Foundation® Identity Broker. | SC - System and Communications Protection |
| | NSX_030 | NSX Manager supports an organization-defined CLI account lockout duration after repeated failed login attempts | AC- Access Control |
| | NSX_031 | NSX Manager supports an CLI account lockout policy to limit the number of failed login attempts before locking out the user. | VMware Best Practice |
| | NSX_032 | NSX Manager supports CLI session timeout at the end of the session or after an organization-defined period of inactivity. | AC- Access Control |
| | NSX_033 | NSX Manager can be configured to disable unused local accounts. | VMware Best Practice |

| | | | |
|---|---|---|---|
| | NSX_034 | NSX supports TLS 1.2 and is the default protocol. | SA - System and Services Acquisition<br>SC - System and Communications Protection |
| | NSX_035 | NSX Manager supports SNMP v3 for commercial-grade security, including authentication, authorization, access control, and privacy. | VMware Best Practice |
| | NSX_036 | NSX must be updated to the current version to support the latest security updates. | SI - System and Information Integrity |
| | NSX_037 | NSX Manager provides management plane protection for denial-of-service attack by having API rate limiting to limit the number of transactions per second and concurrent transactions to the NSX REST API. However, as of now, there is no built-in mechanism to restrict the usage of REST APIs. But such usage can be monitored from logs and ensure that the API usage is granted and approved by your local site policy. | PE - Physical and Environmental Protection<br>RA – Risk Assessment<br>SC - System and Communications Protection<br>SI - System and Information Integrity |
| | NSX_038 | SFTP is supported to encrypt backups and restorations for NSX. | CP - Contingency Planning |
| | NSX_039 | The SFTP server can be hardened with general best practices and guidelines to protect the backups and restorations from common threats and vulnerabilities. | AU - Audit and Accountability |
| | NSX_040 | A remote syslog server or SI - System and Information IntegrityEM can be enabled to collect NSX logs. It is important to ensure the Syslog server is authorized and secure within the NSX Manager Virtual Appliance. | AU - Audit and Accountability |

| | | | |
|---|---|---|---|
| | NSX_041 | NSX Manager Virtual Appliance can be used to verify TLS is being used within the LDAP server settings. | IA - Identification and Authentication |
| | NSX_042 | NSX Distributed Firewall can be configured to send traffic log entries to a central audit server for management and configuration of the traffic log entries. | AU - Audit and Accountability<br>SI - System and Information Integrity |
| | NSX_043 | The NSX Manager has the capability to monitor possible port scan attacks by reviewing the log entries or employing a log management product. | PE - Physical and Environmental Protection<br>RA - Risk Assessment<br>SC - System and Communications Protection<br>SI - System and Information Integrity |

## ESX

| Product | Capability ID | Product Capability | NIST Control Family |
|---|---|---|---|
| ESX | ESX_001 | Remote access to ESX via SSH can be controlled on the ESX host. | AC- Access Control |
| | ESX_002 | Host based authentication to ESX via SSH can be disallowed on the ESX host. | VMware Best Practice |
| | ESX_003 | Root logins to the ESX host can be disabled. | AC- Access Control<br>IA - Identification and Authentication |

| | | | |
|---|---|---|---|
| | ESX_004 | Remote logins to the ESX host can be configured to reject authentication using an empty password. | IA - Identification and Authentication |
| | ESX_005 | User environment settings can be disabled for the ESX host to prevent users from potentially bypassing access restrictions. | CM - Configuration Management |
| | ESX_006 | The ESX host SSH daemon can be configured with strict mode to prevent users from logging into the system as another user. | CA - Assessment, Authorization and Monitoring<br>SA - System and Services Acquisition |
| | ESX_007 | The ESX host can be configured to disallow compression. | CM - Configuration Management |
| | ESX_008 | The ESX host can be configured to block gateway ports to prevent the SSH tunnel from accessing other systems on the internal network, circumventing firewalls and network access control lists. | CM - Configuration Management<br>SA - System and Services Acquisition |
| | ESX_009 | The ESX can be configured to disable x11 forwarding over SSH. | CM - Configuration Management |
| | ESX_010 | The ESX host can be configured to block network tunnels over an SSH connection. | CM - Configuration Management<br>SA - System and Services Acquisition |
| | ESX_011 | A session timeout can be configured for the SSH client session by setting the client alive message count. | AC- Access Control |
| | ESX_012 | A session timeout can be configured for clients that do not actively respond during the connection. | AC- Access Control |
| | ESX_013 | The ESX host enables password enforcement rules such as password complexity. | IA - Identification and Authentication<br>MA - Maintenance |

| | | | |
|---|---|---|---|
| | ESX_014 | The ESX host firewalls can be configured to only allow traffic from the ESX management network. | SC - System and Communications Protection |
| | ESX_015 | The vSphere Client will present a warning if SSH or the ESX Shell is enabled on the ESX hosts. | CM - Configuration Management |
| | ESX_016 | Lockdown mode can be configured on the ESX host disabling direct access. To do so the host will need to be managed remotely from a vCenter Server. | CM - Configuration Management |
| | ESX_017 | The ESX host supports an account lockout policy to limit the number of failed login attempts before locking out the user. | AC- Access Control |
| | ESX_018 | The ESX host supports session timeout at the end of the session or after an organization-defined period of inactivity. | AC- Access Control |
| | ESX_019 | Bridge Protocol Data Unit filtering can be enabled on the ESX host to automatically drop any BPDU packets from being sent to the physical switch. | CM - Configuration Management |
| | ESX_020 | The ESX host firewalls rules can be configured to deny all traffic by default. | SC - System and Communications Protection |
| | ESX_021 | The ESX host firewalls rules can be configured to block all outbound network traffic. | SC - System and Communications Protection |
| | ESX_022 | The ESX host can enable a password reuse restriction setting to prohibit password reuse. | IA - Identification and Authentication |
| | ESX_023 | The ESX host supports the ability to disable SSH to prevent users from remotely connecting to the ESX shell. SSH can be temporarily enabled for maintenance. | CM - Configuration Management<br>SC - System and Communications Protection |
| | ESX_024 | The ESX host supports the ability to disable the ESX Shell Service preventing users from bypassing vCenter RBAC. The ESX Shell Service can be temporarily enabled for maintenance. | VMware Best Practice |

| | | | |
|---|---|---|---|
| | ESX_ 025 | In support of User Access Controls and in particular process controls such as adding, modifying, or removing users, ESX hosts can be integrated with Active Directory to support access controls. | IA - Identification and Authentication |
| | ESX_ 026 | The ESX hosts support the configuration of a logon banner before granting DCUI access. This provides the user with a privacy and security notice consistent with organizational policies, laws and regulations. | AC- Access Control |
| | ESX_ 027 | The ESX hosts support the configuration of a logon banner before granting SSH access. This provides the user with a privacy and security notice consistent with organizational policies, laws and regulations. | AC- Access Control |
| | ESX_ 028 | An exceptions list for lockdown mode can be configured. These predetermined users will not lose their permissions when the host enters lockdown mode. | AC- Access Control<br>CM - Configuration Management |
| | ESX_ 029 | Security patches and updates can be installed for ESX hosts. | SI - System and Information Integrity |
| | ESX_ 030 | ESX hosts can be configured to send all locally stored logs to a persistent log location. | IA - Identification and Authentication |
| | ESX_ 031 | When adding ESX hosts to Active Directory a default group can be configured. It is important to ensure the user/group is not added to the "ESX Admin" group by default. | AC- Access Control<br>SC - System and Communications Protection |
| | ESX_ 032 | The ESX host has the capability to disable Inter-VM transparent page sharing. | CM - Configuration Management |

| | | | |
|---|---|---|---|
| | | | SA - System and Services Acquisition |
| | ESX_033 | ESX system clocks can be synchronized to an NTP time server to enable accurate and universal time source logging. | AU - Audit and Accountability<br>SC - System and Communications Protection |
| | ESX_034 | The ESX host NTP Service Startup Policy can be configured to start and stop with the host. | AU - Audit and Accountability<br>SC - System and Communications Protection |
| | ESX_035 | The ESX Image Profile should be verified to only allow signed vSphere Installation Bundles (VIBs)<br>The ESX host can be configured to support signed VIBs preventing unsigned bundles from being installed. | CM - Configuration Management |
| | ESX_036 | All port groups on ESX standard switches can be configured to reject forged transmits. | SC - System and Communications Protection |
| | ESX_037 | All port groups on ESX standard switches can be configured to reject guest MAC address changes. | SC - System and Communications Protection |
| | ESX_038 | All port groups on ESX standard switches can be configured to reject guest promiscuous mode requests. | SC - System and Communications Protection |
| | ESX_039 | ESX hosts support a DCUI Access List to allow specific predetermined users to exit lockdown mode in case a host becomes isolated from vCenter. | AC- Access Control<br>IA - Identification and Authentication |
| | ESX_040 | ESX hosts can be configured to send logs to a centralized log server | AU - Audit and Accountability |

| | | | |
|---|---|---|---|
| | ESX_041 | The ESX hosts can be configured to enforce an unlock timeout after a user account is locked out. | AC- Access Control |
| | ESX_042 | The ESX host supports the ability to disable the Managed Object Browser (MOB). The MOB is disabled by default since it does not support access controls and could be used to obtain information about a host being targeted for unauthorized access. | VMware Best Practice |
| | ESX_043 | ESX supports DCUI session timeout at the end of the session or after an organization-defined period of timeout. | AC- Access Control |
| | ESX_044 | The ESX host provides the ability to restrict dvfilter network API's. If the dvfilter network API is not in use, then it should not be configured to send network information to a virtual machine. | CM - Configuration Management<br>SC - System and Communications Protection |
| | ESX_045 | The ESX host can be configured to isolate network traffic to a dedicated VLAN. It is highly recommended that vMotion traffic is isolated from all other traffic. | AC- Access Control<br>SC - System and Communications Protection<br>CA - Assessment, Authorization and Monitoring |
| | ESX_046 | ESX hosts can be configured to capture audit records to establish, correlate and investigate events leading up to an outage or attack. | AU - Audit and Accountability<br>MA - Maintenance<br>SI - System and Information Integrity<br>IA - Identification and Authentication |

| | | | |
|---|---|---|---|
| | ESX_047 | ESX supports host client session timeout at the end of the session or after an organization-defined period of timeout. | VMware Best Practice |
| | ESX_048 | OpenSSH on the ESX host supports a FIPS 140-2 validated cryptography module and is enabled by default. | SA - System and Services Acquisition<br>SC - System and Communications Protection |
| | ESX_049 | The ESX host can be configured to isolate network traffic to a dedicated VLAN. It is highly recommended that IP-based storage traffic is isolated from all other traffic. | AC- Access Control<br>SC - System and Communications Protection<br>CA - Assessment, Authorization and Monitoring |
| | ESX_050 | ESX hosts support bidirectional CHAP authentication for traffic. | AC- Access Control<br>IA - Identification and Authentication<br>SC - System and Communications Protection |
| | ESX_051 | All port groups on standard switches can be configured to be different than their native virtual local area network value. | CM - Configuration Management |
| | ESX_052 | The virtual Local Area Network value of all port groups on standard switches can be configured. They should not be configured to VLAN 4095 unless Virtual Guest Tagging (VGT) is required. | CM - Configuration Management |
| | ESX_053 | All port groups on standard switches can be configured but they should not be configured to VLAN values reserved by upstream physical switches. | CM - Configuration Management |

| | | | |
|---|---|---|---|
| | ESX_054 | CIM service account permissions on the ESX hosts can be limited to a read-only or custom role. | AC- Access Control |
| | ESX_055 | The ESX host supports secure TLS (TLS 1.2) cryptographic controls for all endpoints. | SA - System and Services Acquisition<br>SC - System and Communications Protection |
| | ESX_056 | ESX can be configured to enable Secure Boot for all guest OS. With UEFI Secure Boot enabled, a host refuses to load any UEFI driver or app unless the operating system bootloader has a valid digital signature. | SI - System and Information Integrity |
| | ESX_057 | The ESX Shell can be configured to disable port forwarding for ESX host SSH daemon. | CM - Configuration Management |
| | ESX_058 | The OpenSLP service can be disabled on the ESX host and be configured to start and stop manually when needed. | VMware Best Practice |
| | ESX_059 | The default self-signed host certificate issued by the VMware Certificate Authority (VMCA) can and should be replaced with a DOD-approved certificate when the host is accessed directly. | SC - System and Communications Protection |
| | ESX_060 | The ESX SNMP service can be hardened if it is in use by configuring the proper trap destination. If the service is not in use, it can be disabled. | CM - Configuration Management<br>SA - System and Services Acquisition |
| | ESX_061 | When sending syslog data to a remote host, ESX can be configured to use any combination of TCP - Contingency Planning, UDP and SSL transports. When using SSL, the server certificate must be validated to ensure that the host is connecting to a valid syslog server. | AC- Access Control<br>IA - Identification and Authentication<br>SC - System and Communications Protection |

| | | | |
|---|---|---|---|
| | ESX_062 | The ESX host supports a session timeout for the vSphere API at the end of the session or after an organization-defined period of timeout. | VMware Best Practice |
| | ESX_063 | The ESX host http proxy daemon is capable of using FIPS 140-2 validated cryptographic modules to protect the confidentiality of remote access sessions. | SA - System and Services Acquisition<br>SC - System and Communications Protection |
| | ESX_064 | The ESX host can be configured to not override virtual machine configurations. This can be managed and automated per-VM vmx settings. | CM - Configuration Management<br>AC- Access Control |
| | ESX_065 | The ESX host can be configured to not override virtual machine settings. This can be managed and automated per-VM vmx settings. | CM - Configuration Management<br>AC- Access Control |
| | ESX_066 | The ESX host can enable strict x509 verification for SSL syslog endpoints. | AC- Access Control<br>IA - Identification and Authentication<br>SC - System and Communications Protection |
| | ESX_067 | Volatile key destruction can be enabled on the ESX host. | SA - System and Services Acquisition<br>SC - System and Communications Protection |
| | ESX_068 | The ESX host enables password enforcement rules such as maximum password age. | VMware Best Practice |

| | | | |
|---|---|---|---|
| | ESX_069 | The CIM service on ESX can be disabled if not in use. | VMware Best Practice |
| | ESX_070 | The ESX host SSH daemon can be configured to only use FIPS 140-2 validated ciphers. | SA - System and Services Acquisition<br>SC - System and Communications Protection |
| | ESX_071 | The SNMP service on ESX can be disabled if not in use. | VMware Best Practice |
| | ESX_072 | A trusted platform module (TPM) 2.0 can be installed and enabled on the ESX host | SI - System and Information Integrity |
| | ESX_073 | Broadcom provides the latest security updates on vendor support websites, including end of life status. | SI - System and Information Integrity |
| | ESX_074 | IT infrastructure management interfaces can be isolated on their own network segment or as part of an isolated management network to support better access controls. | SC - System and Communications Protection |
| | ESX_075 | Hardware management controllers and other hardware management functionality/tools can be disabled if they are not in use or provide little value. | SA - System and Services Acquisition |
| | ESX_076 | Remote access to ESX via SSH can be controlled on the ESX host. | AC- Access Control |
| | ESX_077 | Host based authentication to ESX via SSH can be disallowed on the ESX host. | VMware Best Practice |
| | ESX_078 | Root logins to the ESX host can be disabled. | AC- Access Control<br>IA - Identification and Authentication |
| | ESX_079 | Remote logins to the ESX host can be configured to reject authentication using an empty password. | IA - Identification and Authentication |

## vCenter

| Product | Capability ID | Product Capability | NIST Control Family |
|---|---|---|---|
| vCenter | vCenter_001 | Parallel devices on the virtual machine that have not been authorized can be detected through manual review or by running a command in the Power CLI command prompt. | SC - System and Communications Protection |
| | vCenter_002 | Serial devices on the virtual machine that have not been authorized can be detected through manual review or by running a command in the Power CLI command prompt. | SC - System and Communications Protection |
| | vCenter_003 | USB devices on the virtual machine that have not been authorized can be detected through manual review or by running a command in the Power CLI command prompt. | AC- Access Control<br>MP - Media Protection |
| | vCenter_004 | Shared salt values can be disabled on the virtual machine. | CM - Configuration Management<br>SC - System and Communications Protection |
| | vCenter_005 | Copy operations can be disabled on the virtual machine. | CM - Configuration Management<br>SC - System and Communications Protection |

| | | | |
|---|---|---|---|
| | vCenter_006 | Drag and drop operations on the virtual machine can be disabled. | CM - Configuration Management<br>SC - System and Communications Protection |
| | vCenter_007 | Paste operations can be disabled on the virtual machine. | CM - Configuration Management<br>SC - System and Communications Protection |
| | vCenter_008 | Virtual disk shrinking can be disabled on virtual machines. | CM - Configuration Management |
| | vCenter_009 | Virtual disk erasure can be disabled on virtual machines. | CM - Configuration Management |
| | vCenter_010 | Console connection sharing can be limited through the vSphere Client. This prevents a non-administrator in the VM from connecting to the console and potentially observing an administrator's actions. | AC- Access Control |
| | vCenter_011 | Informational messages from the VM to the VMX file can be configured to a specific capacity on the virtual machine. It is recommended that this value is set to 1MB but can be modified for organizational needs. | CM - Configuration Management |
| | vCenter_012 | Within the vSphere Client a configuration can be made to prevent unauthorized device modifications in virtual machines by blocking non-admin users or processes from connecting, disconnecting, or adjusting device settings. | AC- Access Control<br>SI - System and Information Integrity |

| | | | |
|---|---|---|---|
| | vCenter_013 | Virtual machines can be configured to obtain host information from the hypervisor. It is recommended to disable this configuration for all VMs unless a particular VM requires this information for performance monitoring. | AC- Access Control |
| | vCenter_014 | Independent, non-persistent disks on the virtual machine should not be used and can be detected through manual review or by running a command in the Power CLI command prompt. | AC- Access Control<br>MP - Media Protection |
| | vCenter_015 | Floppy disks on the virtual machine that have not been authorized can be detected by running a command in the Power CLI command prompt. | AC- Access Control<br>MP - Media Protection |
| | vCenter_016 | CD/DVD devices on the virtual machine that have not been authorized can be detected through manual review or by running a command in the Power CLI command prompt. | AC- Access Control<br>MP - Media Protection |
| | vCenter_017 | Service account reviews can be performed in the system. No application should share a service account when connecting to vCenter Server. | AC- Access Control |
| | vCenter_018 | vCenter can enable a password reuse restriction setting to prohibit password reuse | IA - Identification and Authentication |
| | vCenter_019 | ESX Hosts can be configured to capture audit records to establish, correlate and investigate events leading up to an outage or attack. | AU - Audit and Accountability<br>MA - Maintenance<br>SI - System and Information Integrity |

| | | | |
|---|---|---|---|
| | | | IA - Identification and Authentication<br>AC- Access Control |
| | vCenter_020 | vCenter can set the distributed port group to a Promiscuous Mode. This prevents all connected virtual machines from reading all packets across the network. | SC - System and Communications Protection |
| | vCenter_021 | vCenter includes a vSphere Client extensibility framework, which provides the ability to extend the vSphere Client with menu selections or toolbar icons that provide access to vCenter add-on components or external, web-based functionality. vSphere Client plugins or extensions run at the same privilege level as the user. When using these plug-ins, ensure only verified trusted sources are allowed. | CM - Configuration Management |
| | vCenter_022 | All distributed port groups on vCenter can be configured to reject MAC address changes. | SC - System and Communications Protection |
| | vCenter_023 | vCenter enables password enforcement rules such as a minimum upper case character policy. | VMware Best Practice |
| | vCenter_024 | vCenter can manage excess capacity, bandwidth, or other redundancy to limit the effects of information-flooding types of Denial of Service (DoS) attacks by enabling Network I/O Control (NIOC). | AC- Access Control<br>SC - System and Communications Protection<br>CA - Assessment, Authorization and Monitoring |

| | | | |
|---|---|---|---|
| | vCenter_025 | vCenter enables password enforcement rules such as a minimum password length policy. | VMware Best Practice |
| | vCenter_026 | vCenter enables password enforcement rules such as a minimum lower case character policy. | VMware Best Practice |
| | vCenter_027 | vCenter comes with pre-defined roles that can be assigned to enable Role Based Access Control. In addition, new roles can be developed based on an inventory of functionality to be used as custom roles. This capability can support both Separation of Duties, as well as the concept of Least Privilege. | AC- Access Control |
| | vCenter_028 | The distributed virtual switch can export NetFlow information about traffic crossing the switch. NetFlow exports are not encrypted and can contain information about the virtual network, making it easier for a man-in-the-middle attack to be executed successfully. If NetFlow export is required, verify that all NetFlow target Internet Protocols (IPs) are correct. | AC- Access Control |
| | vCenter_029 | The vSAN Health Check is able to download the public Hardware Compatibility list. However, it is important to ensure the vCenter server is not directly downloading content from the internet. It is recommended to have this functionality disabled and if this feature is necessary, an external proxy server can be configured instead. | SC - System and Communications Protection |
| | vCenter_030 | The vSAN Datastore can be configured with a unique name preventing confusion if multiple datastores are in use. | CM - Configuration Management |
| | vCenter_031 | vCenter enables password enforcement rules such as a maximum password age policy. | VMware Best Practice |
| | vCenter_032 | A session timeout can be configured for the management session after a certain period of inactivity. | AC- Access Control |
| | vCenter_033 | VPX users can have their minimum password length set separately. It is highly recommended that the | VMware Best Practice |

| | | | |
|---|---|---|---|
| | | default length is set to at least 32 characters for these accounts. | |
| | vCenter_034 | By default, vCenter will change the "vpxuser" password automatically every 30 days. Ensure this setting meets site policies. If it does not, configure it to meet password aging policies. | IA - Identification and Authentication |
| | vCenter_035 | vCenter enables password enforcement rules/policies such as a minimum number of special characters policy. | VMware Best Practice |
| | vCenter_036 | vCenter enables password enforcement rules/policies such as a minimum number of numeric characters policy. | VMware Best Practice |
| | vCenter_037 | vCenter can be configured with an account lockout policy to set a time interval between failures. | AC- Access Control |
| | vCenter_038 | vCenter can be configured with an account lockout policy to require an administrator to unlock accounts after excessive login failures. | AC- Access Control |
| | vCenter_039 | vCenter can be configured with an account lockout policy to set a maximum number of failed login attempts. | VMware Best Practice |
| | vCenter_040 | vCenter provides a built-in SSO administrator account. This account should be used for emergencies only and be governed by policy. | AC- Access Control<br>IA - Identification and Authentication |
| | vCenter_041 | All distributed port groups on vCenter can be configured to reject forged transmits. | SC - System and Communications Protection |

| | | | |
|---|---|---|---|
| | vCenter_042 | PCI passthrough can be enabled to direct assignment of hardware PCI functions to virtual machines. It is recommended to only have this feature enabled on virtual machines that need it. | CM - Configuration Management<br>SC - System and Communications Protection |
| | vCenter_043 | vCenter provides the capability to enable/disable the distributed virtual switch health check. It is turned off by default and is recommended to only be used when troubleshooting. | CM - Configuration Management<br>SC - System and Communications Protection |
| | vCenter_044 | All port groups on standard switches can be configured to be different than their native virtual local area network value. | CM - Configuration Management |
| | vCenter_045 | All port groups on standard switches can be configured but they should not be configured to VLAN values reserved by upstream physical switches. | CM - Configuration Management |
| | vCenter_046 | vCenter is configured to use TLS 1.2 by default. | SA - System and Services Acquisition<br>SC - System and Communications Protection |
| | vCenter_047 | The default self-signed, VMware Certificate Authority (VMCA)-issued vCenter reverse proxy certificate can be replaced with a DOD-approved certificate. The use of a DOD certificate on the vCenter reverse proxy and other services assures clients that the service they are connecting to is legitimate and trusted. | SC - System and Communications Protection |

| | | | |
|---|---|---|---|
| | vCenter_048 | vCenter supports the configuration of a logon banner before granting access to the system. This provides the user with a privacy and security notice consistent with organizational policies, laws and regulations. | AC- Access Control |
| | vCenter_049 | Users/groups can be assigned to a default role within vCenter. It is important to ensure the user/group is not added to any of the 4 default roles that contain cryptographic permissions. | SA - System and Services Acquisition<br>SC - System and Communications Protection |
| | vCenter_050 | Users/groups can be assigned specific cryptographic permissions within vCenter. It is important to ensure only the administrator is assigned any of these permissions. | SA - System and Services Acquisition<br>SC - System and Communications Protection |
| | vCenter_051 | Mutual CHAP for vSAN Integrity targets can be configured from the vSphere client. When enabled, vSphere performs bidirectional authentication of both the Integrity target and host. | AC- Access Control<br>IA - Identification and Authentication<br>SC - System and Communications Protection |
| | vCenter_052 | Key Encryption Keys (KEKs) can be configured to be reissued at regular intervals for the vSAN encrypted databases. | VMware Best Practice |
| | vCenter_053 | The dvFilter API can be used to filter and inspect network traffic. Access to the virtual machines through the dvFilter network APIs can be controlled and limited. | SA - System and Services Acquisition |

| | | | |
|---|---|---|---|
| | vCenter_054 | vCenter provides the ability for users to be added to predefined or custom groups. vCenter SSO integrates with PAM in the underlying Photon operating system so members of the "SystemConfiguration.BashShellAdministrators" SSO group can log on to the operating system without needing a separate account. It is recommended that users have strict authorization to be a part of this group. | AC- Access Control |
| | vCenter_055 | vCenter provides the ability for users to be added to predefined or custom groups. The vSphere "TrustedAdmins" group grants additional rights to administer the vSphere Trust Authority feature. It is recommended that users have strict authorization to be a part of this group | AC- Access Control |
| | vCenter_056 | vCenter can push near real time logs to be stored in an external centralized log server. | AU - Audit and Accountability |
| | vCenter_057 | vCenter has the capability to configure alarms tied to event IDs to notify users if a certain event or action takes place. These alerts can be set up to alert the appropriate personnel about any SSO account actions. | AC- Access Control |
| | vCenter_058 | Backups of vCenter can be made at a data and configuration level versus traditional storage/image-based backups. This reduces recovery time by letting the system administrator (SA - System and Services Acquisition) spin up a new vCenter while simultaneously importing the backed-up data. | CP - Contingency Planning |
| | vCenter_059 | vCenter can generate volumes of security relevant application-level events and has the capability to send these events to be stored in an external centralized log server. | AU - Audit and Accountability<br>SI - System and Information Integrity |
| | vCenter_060 | vCenter supports SNMP v3 security features where SNMP is required. | VMware Best Practice |

| | | | |
|---|---|---|---|
| | vCenter_061 | vCenter can be configured to isolate network traffic to a dedicated VLAN or other network segments. It is highly recommended that IP-based storage traffic on distributed switches is isolated from all other traffic. | SC - System and Communications Protection |
| | vCenter_062 | vCenter task retention and vCenter event retention and be set to a defined number of days. The default value is 30 days but can be modified based on organizational needs. | AU - Audit and Accountability<br>SC - System and Communications Protection<br>AC- Access Control<br>SI - System and Information Integrity |
| | vCenter_063 | vCenter allows port groups to be configured to VLAN Trunking, allowing the vSwitch to pass all network frames in the specified range to the attached virtual machines without modifying the virtual local area network (VLAN) tags. It is recommended that this is configured only if required and as authorized by Virtual Guest Tagging. | CM - Configuration Management |
| | vCenter_064 | vCenter can employ active directory as an authentication mechanism. Additionally, the identity provider can be embedded with either Windows Integrated Authentication or LDAP. | AC- Access Control |
| | vCenter_065 | vCenter supports LDAPS to protect the confidentiality of LDAP communications. | IA - Identification and Authentication |
| | vCenter_066 | The LDAP identity source can be configured using a limited privileged account. | AC- Access Control<br>SI - System and Information Integrity |

| | | | |
|---|---|---|---|
| | vCenter_067 | The guest operating system can be configured to be locked when the last console user disconnects. This setting only applies to Windows-based virtual machines with VMware tools installed. | AC- Access Control |
| | vCenter_068 | Virtual machines can use 3D graphic features. These features are off by default and are recommended to not be used unless the virtual machine requires 3D functionality. | CM - Configuration Management<br>SC - System and Communications Protection |
| | vCenter_069 | vCenter supports 256-bit AES-GCM - Configuration Management encryption for vMotion on the virtual machine. | AU - Audit and Accountability |
| | vCenter_070 | vCenter supports the ability to use premade templates to deploy virtual machines. | CM - Configuration Management |
| | vCenter_071 | The virtual machine console can be removed from the standard virtual machine role. | SC - System and Communications Protection |
| | vCenter_072 | vCenter supports SNMP v3 commercial-grade security, including authentication, authorization, access control, and privacy. Previous versions of the protocol contained well-known security weaknesses that were easily exploited. Therefore, SNMP v1/2 receivers can be disabled, while SNMP v3 is configured in another control. vCenter exposes SNMP v1/2 in the UI and SNMP v3 in the CLI. | SA - System and Services Acquisition<br>SC - System and Communications Protection |
| | vCenter_073 | The vCenter Native Key acts as a key provider for encryption-based capabilities such as encrypted virtual machines without requiring an external KMS solution. When enabling this feature, a backup can be created using a strong password. | SC - System and Communications Protection |

| | | | |
|---|---|---|---|
| | vCenter_074 | vCenter can be configured to capture logs throughout the system. | CM - Configuration Management<br><br>AU - Audit and Accountability |
| | vCenter_075 | The virtual machines can be configured to capture logs. Log collection is enabled by default through the ESX hypervisor. | AU - Audit and Accountability |
| | vCenter_076 | The ESX hypervisor maintains logs for each individual VM by default. These logs contain information including but not limited to power events, system failure information, tools status and activity, time sync, virtual hardware changes, vMotion migrations, and machine clones.<br><br>By default, the size of these logs is unlimited, and they are only rotated on vMotion or power events. This can cause storage issues at scale for VMs that do not vMotion or power cycle often. It is recommended to set a log size appropriate for your system. | AU - Audit and Accountability |
| | vCenter_077 | By default, 10 of these logs for virtual machines are retained. This is normally sufficient for most environments, but this configuration can be verified, updated and maintained. | AU - Audit and Accountability<br><br>SC - System and Communications Protection<br><br>AC- Access Control<br><br>SI - System and Information Integrity |
| | vCenter_078 | vSphere Fault Tolerance performs frequent checks between a primary VM and secondary VM so the secondary VM can quickly resume from the last successful checkpoint. The checkpoint contains the | SC - System and Communications Protection |

| | | | |
|---|---|---|---|
| | | VM state that has been modified since the previous checkpoint.<br><br>Encryption can be enabled for Fault Tolerance. By default, the encryption is set to "Opportunistic", which means it enables encryption only if both the primary and secondary host are capable of encryption. | |
| | vCenter_079 | vCenter can automatically synchronize internal information system clocks to an authoritative time server. | AU - Audit and Accountability<br><br>SC - System and Communications Protection |
| | vCenter_080 | Unnecessary services or services not in use can be disabled such as CDP or LLDP network discovery protocol. | VMware Best Practice |
| | vCenter_081 | The vSphere Distributed Virtual Switch can enable port mirroring sessions allowing traffic to be mirrored from one source to a destination. To maintain security, any unauthorized port mirroring sessions on distributed switches should be promptly removed. | SC - System and Communications Protection |
| | vCenter_082 | vCenter is intended to be managed through VAMI, vSphere Client, and APIs. SSH can be disabled unless and temporarily turned on for troubleshooting and support. | CM - Configuration Management<br><br>SC - System and Communications Protection |
| | vCenter_083 | vCenter network firewall rules in conjunction with network/perimeter firewall rules can be configured to deny all traffic, except explicitly designated traffic. | SC - System and Communications Protection |
| | vCenter_084 | Unnecessary computer interfaces such as NICs can be disabled through vCenter. | SC - System and |

| | | | |
|---|---|---|---|
| | | | Communications Protection |
| | vCenter_085 | Security patches and updates can be installed for vCenter. vCenter should be updated first and then users can proceed with updating ESX hosts if an update is available. | SI - System and Information Integrity |

## Telco Cloud Automation

| Product | Capability ID | Product Capability | NIST Control Family |
|---|---|---|---|
| Telco Cloud Automation | TCA_1 | A session timeout can be configured for Telco Cloud Automation main UI. This timeout is configured within the administration settings, and the timeout is also applied to the API. | AC - Access Management |
| | TCA_2 | Active tenant sessions can be managed within the Telco Cloud Automation Appliance Manager. An administrator can view session details and terminate a session. | AC - Access Management |
| | TCA_3 | Three types of system level user accounts are created during the deployment of Telco Cloud Automation Manager or Telco Cloud Automation Control Plane. | AC - Access Management<br>IA - Identity and Access Management |
| | TCA_4 | System level accounts do not have default passwords configured. The passwords for each type of account can be set to ensure they meet organizations password requirements including complexity. | AC - Access Management<br>IA - Identity and Access Management |
| | TCA_5 | System level accounts can be configured with password expiration. By default, admin user accounts expire every 90 days. | AC - Access Management<br>IA - Identity and Access Management |

| | | | |
|---|---|---|---|
| | TCA_6 | By default, the Telco Cloud Automation appliance is configured to lock system level accounts after three failed login attempts within a 15-minute period. | AC - Access Management |
| | TCA_7 | For remote connections all Telco Cloud Automation appliances include the SSH protocol. | AC - Access Management |
| | TCA_8 | The Web Console for the Telco Cloud Automation Manager or Telco Cloud Automation Control Plane supports the ability to disable SSH to prevent users from remotely connecting to the appliances. SSH can be temporarily enabled for maintenance and troubleshooting. | AC - Access Management<br>SA - System and Services Acquisition<br>CM - Configuration Management<br>SC - System and Communication Protection |
| | TCA_9 | A log bundle can be requested for Telco Cloud Automation. The log bundle can contain application logs, database dump and Kubernetes cluster logs. | AU - Audit and Accountability |
| | TCA_10 | Audit logs for the Telco Cloud Automation can be monitored within the Telco Cloud Automation UI. This UI contains all events that occurred within the platform for two months. | AU - Audit and Accountability<br>SC - System and Communication Protection<br>SI – System and Information Integrity |
| | TCA_11 | The log destination for Telco Cloud Automation audit logs can be sent to vRealize Log Insight for analysis by configuring the log destination in the Telco Cloud Automation appliance manager. | AU - Audit and Accountability<br>SI - System and Information Integrity |

| | | | |
|---|---|---|---|
| | TCA_12 | Telco Cloud Automation logs can be forwarded to an external log aggregator to correlate logs and analyze suspicious activity. | AU - Audit and Accountability<br><br>SI - System and Information Integrity |
| | TCA_13 | NTP servers can be configured to synchronize system clocks, allowing the correlation of events that occur across multiple systems. | AU - Audit and Accountability<br><br>SC - System and Communication Protection |
| | TCA_14 | All non-essential ports and protocols can be deactivated. The minimum incoming and outgoing ports for Telco Cloud Automation can be configured. | CM - Configuration Management |
| | TCA_15 | Broadcom documents the minimum required ports and protocols for Telco Cloud Automation, allowing firewalls and routers to be easily configured. | CM - Configuration Management |
| | TCA_16 | Software installation can be managed through monitoring the inventory of installed products. | CM - Configuration Management<br>SI - System and Information Integrity |
| | TCA_17 | Software installations can be managed and restricted to essential software. It is not recommended to use any third-party software that Broadcom does not support. | CM - Configuration Management |
| | TCA_18 | Telco Cloud Automation keeps track of its installation, patching, and upgrade history to audit version changes. | CM - Configuration Management<br>PM – Program Management |

| | | | |
|---|---|---|---|
| | TCA_19 | Backup bundles can be created through the Telco Cloud Automation Appliance Manager. When a backup is generated, there is a togglable option to encrypt the backup. | CP - Contingency Planning |
| | TCA_20 | Within the appliance manager, you can configure an SFTP protocol setting to automatically transfer backup files to a designated remote server. | SA - System and Services Acquisition<br>CP - Contingency Planning |
| | TCA_21 | Broadcom provides security advisories for any vulnerabilities or guidance related to VMware products. The installation, patching and upgrade history can be used to verify the released advisories are enforced. | PM – Program Management |
| | TCA_22 | VMware vSphere environment can be hardened to provide a secure Telco Cloud Automation environment. Broadcom provides vSphere hardening standards. | SA - System and Services Acquisition |
| | TCA_23 | Users must harden the software infrastructure components such as the operating system, supporting software and database software to ensure a completely hardened and secure environment. | SA - System and Services Acquisition |
| | TCA_24 | Telco Cloud Automation and other HTTPS endpoints can be secured using signed certificates. | SC - System and Communication Protection |
| | TCA_25 | The network communication settings for any VMware virtual appliances and host machines are available to review and configure. | SC - System and Communication Protection |
| | TCA_26 | By default, the Telco Cloud Automation Manager and Telco Cloud Automation Control Plane appliances are deployed with self-signed TLS certificates. These default certificates can be | SC - System and Communication Protection |

| | | | |
|---|---|---|---|
| | | replaced with organization-issued or trusted CA-signed certificates to ensure secure, authenticated communications. | |
| | TCA_27 | Before installing Telco Cloud Automation, the integrity of the installation media can be verified by comparing the checksum sha256 value with the sha256 hash published on Broadcom Support Portal. | SI - System and Information Integrity |
| | TCA_28 | Telco Cloud Automation integrates Photon OS security patches and critical package updates into each release. Regularly upgrading to the latest Telco Cloud Automation release ensures timely application of all underlying Linux security updates. | SI - System and Information Integrity |
| | TCA_29 | Telco Cloud Automation can be deployed in an air-gapped or internet-restricted environment, reducing exposure to external networks. | SC - System and Communication Protection |
| | TCA_30 | Open Policy Agent (OPA) Gatekeeper can be used to apply security policies to achieve required security hardening / compliance in Kubernetes Clusters. | CM - Configuration Management |
| | TCA_31 | OPA Gatekeeper identifies two types of policy violations to allow administrators to monitor configuration compliance on Kubernetes clusters and prevent misconfigurations from reaching production. | CM - Configuration Management |

## Tanzu Kubernetes Grid

| Product | Capability ID | Product Capability | NIST Control Family |
|---|---|---|---|
| Tanzu Kubernetes Grid | TKG_1 | Audit logs can be enabled on a standalone management cluster or a workload before the cluster is deployed. | AU - Audit and Accountability |

| | | | |
|---|---|---|---|
| | TKG_2 | Kubernetes audit logs can be forwarded to a specific log destination by using a log forwarder or customizing the settings in the audit log configuration | AU - Audit and Accountability |
| | TKG_3 | Audit policy files can be created to finetune the information that is logged to ensure the system can capture the level of audit log detail defined by the organization. | AU - Audit and Accountability<br>CM - Configuration Management |
| | TKG_4 | The audit log retention for the Kubernetes API can be configured. | AU - Audit and Accountability<br>CM - Configuration Management |
| | TKG_5 | Customers can configure a remote server for offloading audit logs at a predefined frequency.<br><br>The Photon operating system can offload real-time logs through the fluentbit package. | AU - Audit and Accountability |
| | TKG_6 | Notifications can be configured to send an alert via syslog in the event of an audit processing failure or storage exceeding the predefined capacity threshold. | AU - Audit and Accountability |
| | TKG_7 | NTP servers can be configured to synchronize system clocks, allowing the correlation of events that occur across multiple systems. If Tanzu Kubernetes Grid is running on vSphere, the hosts should be synchronized to the same NTP servers. | AU - Audit and Accountability |
| | TKG_8 | Audit tools can and should be cryptographically signed so the organization has the capability of identifying when audit tools have been modified, manipulated, or replaced. | AU - Audit and Accountability |

| | | | |
|---|---|---|---|
| | TKG_9 | Audit logs can be enabled in Photon OS. Settings can be configured to categorize these logs and control where they are sent in the system log. This includes logging for Secure Shell (SSH). | AU - Audit and Accountability<br><br>SI - System and Information Integrity |
| | TKG_10 | RBAC can be configured for accounts that need access to Audit logs. | AC – Access Management<br><br>AU - Audit and Accountability |
| | TKG_11 | Audit logging can be enabled to capture logs during Photon OS startup. This ensures all startup processes are captured. | AU - Audit and Accountability |
| | TKG_12 | By default, non-privileged users are blocked from downloading and executing software. | CM - Configuration Management |
| | TKG_13 | The Photon OS can be configured to enable the TDNF package management tool which will cryptographically verify the authenticity of all software packages during installation. | CM - Configuration Management |
| | TKG_14 | The owner of each Kubernetes component (kubelet, manifest, API server, etcd, admin.conf, kubeadm.conf, kube proxy etc.) configuration files can be configured to limit access to the root to prevent unauthorized access. | CM - Configuration Management |
| | TKG_15 | The permissions on the different Kubernetes component (kubelet, manifest, API server, etcd, admin.conf, kubeadm.conf, kube proxy etc.) configuration files can be restricted to prevent an attacker from modifying Kubernetes in a way for them to bypass user authorizations | CM - Configuration Management |
| | TKG_16 | The Kubernetes kubelet can be configured to deny hostname override. This prevents a user from changing the hostname which would cause issues with matching the audit logs and metrics to the machine's actual hostname. | CM - Configuration Management |

| | | | |
|---|---|---|---|
| | TKG_17 | Unnecessary kernel modules on the Photon OS can be disabled so the operating system only provides essential capabilities. | CM - Configuration Management |
| | TKG_18 | The Kubernetes Controller Manager can be disabled to prevent the exposure of Kubernetes architecture details. This service can be enabled if it is deemed necessary. | CM - Configuration Management |
| | TKG_19 | The Kubernetes API server ports, protocols and services can be configured and disabled to provide only essential connections. | CM - Configuration Management |
| | TKG_20 | The Photon OS can be configured to disable the system from sending and accepting IPv4 Internet Control Message redirects. | CM - Configuration Management |
| | TKG_21 | An external OIDC or LDAP identity provider can be configured within the Tanzu Kubernetes Grid to manage accounts, identifiers, passwords, banners and messages while controlling user access to the workload clusters. | AC - Access Management<br>IA - Identity and Access Management |
| | TKG_22 | Tanzu Kubernetes Grid supports multifactor authentication for network access to both privileged and non-privileged accounts through an integration with MFA supported OIDC or LDAP identity providers. | AC - Access Management<br>IA - Identity and Access Management |
| | TKG_23 | Role Based Access Control can be configured for non-admin accounts within Tanzu Kubernetes Grid. In addition, new roles can be developed based on an inventory of functionality to be used as custom roles. This capability can support both Separation of Duties, as well as the concept of Least Privilege. | AC - Access Management<br>CM - Configuration Management |
| | TKG_24 | A DoD login banner can be configured on any Linux based custom machine, including Tanzu Kubernetes Grid Photon OS nodes. | AC - Access Management |
| | TKG_25 | Kubernetes audit logs can capture all requests made to the API server, including actions such as RoleBinding creation, modification, and deletion. | AC - Access Management |

| | | | |
|---|---|---|---|
| | | | AU - Audit and Accountability |
| | TKG_26 | Shared or group accounts are not configurable on Tanzu Kubernetes Grid. | AC - Access Management |
| | TKG_27 | The number of containers that run with higher privileges can be configured to a handful of namespaces to prevent privilege escalation. | AC - Access Management |
| | TKG_28 | Session timeout can be configured for the Photon OS. | AC - Access Management |
| | TKG_29 | OpenSSH on the Photon OS supports FIPS 140-2 validated OpenSSL cryptography module. | CM - Configuration Management<br>MA – Maintenance<br>SC - System and Communication Protection |
| | TKG_30 | Photon OS can be configured to prohibit empty password logins for SSH even if a user somehow has an empty password on the OS. | IA - Identity and Access Management |
| | TKG_31 | Approved Message Authentication Codes (MAC's) can be implemented on the Photon OS to protect the integrity of remote access sessions. | IA - Identity and Access Management<br>SC - System and Communication Protection<br>SI - System and Information Integrity |

| | | | |
|---|---|---|---|
| | TKG_32 | Tanzu Kubernetes Grid supports individual authentication prior to gaining access to or interacting with shared service accounts. | IA - Identity and Access Management |
| | TKG_33 | SSH access to Photon OS nodes uses key-based authentication. | IA - Identity and Access Management |
| | TKG_34 | The ESX host can be configured to enable bidirectional Challenge-Handshake Authentication Protocol for both the iSCSI target and host. | IA - Identity and Access Management |
| | TKG_35 | Password policies can be configured for local accounts on the Photon Operating System. The password configurations support complexity, length, minimum/maximum password age, reuse restrictions, and minimum number of characters changed. | IA - Identity and Access Management |
| | TKG_36 | Photon OS supports the ability to require a password change upon first login. | IA - Identity and Access Management |
| | TKG_37 | The Photon OS supports reauthentication for privilege escalation. | IA - Identity and Access Management |
| | TKG_38 | Kubernetes namespaces can be configured to logically partition a single Kubernetes cluster into multiple sub-clusters. This can be used to separate user functionality from system management functionality. | SC - System and Communicatio n Protection |
| | TKG_39 | Access to the kernel message buffer in the Photon OS can be restricted to prevent attackers from gaining additional system information as a nonprivileged user. | SC - System and Communicatio n Protection |
| | TKG_40 | TCP syncookies can be configured on the Photon OS to verify the initiator is attempting a valid connection and not a flood source. This helps protect against denial of service (DOS) attacks stemming from a TCP SYN flood attack. | SC - System and Communicatio n Protection |

| | | | |
|---|---|---|---|
| | TKG_41 | Secure Shell (SSH) sessions within the Photon OS can be configured to terminate after a predefined timeframe. | SC - System and Communication Protection |
| | TKG_42 | FIPS 140-2 validated cryptography can be enabled for the Photon OS | SC - System and Communication Protection |
| | TKG_43 | Address space layout randomization can be implemented on the Photon OS to protect its memory from unauthorized code execution. | SI - System and Information Integrity |
| | TKG_44 | Symlink access control protection can be enabled at the kernel level on Photon OS to protect against unauthorized access to sensitive files or escalate privileges. | AC - Access Management<br>CM - Configuration Management |
| | TKG_45 | Photon OS can be configured to disable environmental processing. | CM - Configuration Management |

# About Tevora

Tevora is a leading management consulting firm specializing in enterprise risk, compliance, information security solutions, and threat research. We offer a comprehensive portfolio of information security solutions and services to clients in virtually all industries and also serve institutional and government clients.

Tevora's leaders are professionals with years of experience and records of accomplishments in technology as well as business. This dual background means that we understand the importance of growth and profitability and our solutions are designed to enhance both.

As a consulting firm that can fully implement whatever it recommends, Tevora works with all of the industry's top vendors, yet is beholden to none. We are completely vendor-independent and select best-of-breed products tailored exclusively to our clients' needs. Security is our only business and our single-minded focus on anticipating and solving client problems has been described as "obsessive." We consider this a fair assessment.

Our hard work and dedication have established us as a reliable partner CTOs CIOs, and CISOs can depend on to help protect against threats, both internal and external. With Tevora as a partner, business leaders can devote their energies to enhancing the overall value of information technology to their enterprise.

Tevora is a Qualified Security Assessor (QSA) and Payment Application Qualified Security Assessor (PA-QSA) in good standing with the PCI Security Standards Council. Tevora is also a DVBE (Disabled Veteran Business Enterprise) certified by the California General Services Department (Cert REF# 32786).

For more information, please visit www.tevora.com.

# About Broadcom

Broadcom Inc. (NASDAQ: AVGO) is a global technology leader that designs, develops, and supplies a broad range of semiconductor, enterprise software, and security solutions. Broadcom's category-leading product portfolio serves critical markets including cloud, data center, networking, broadband, wireless, storage, industrial, and enterprise software.

Our solutions include service provider and enterprise networking and storage, mobile device and broadband connectivity, mainframe, cybersecurity, and private and hybrid cloud infrastructure. Broadcom is a Delaware corporation headquartered in San Jose, CA.

Broadcom's VMware software manages cloud complexity so customers can modernize infrastructure, accelerate app development, and protect workloads, wherever these reside.

Our flagship cloud solutions provide the security and performance of private cloud combined with the scale and agility of public cloud. Modern app, edge infrastructure, and private AI products extend these

capabilities, while security and disaster recovery help ensure that customers' operations continue uninterrupted.

From the data center to the cloud and apps to the edge, we help enterprises around the globe become more innovative, connected, resilient and secure.

For more information, visit vmware.com.

TEVORA™

Go forward. We've got your back.

Compliance – Enterprise Risk Management – Data Privacy – Security Solutions – Threat Management